



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie BSI TR-03176

IT-Sicherheitsanforderungen an die Datenübermittlung in der
Registermodernisierung

Version 0.97

KOMMENTIERUNGSVERSION



Änderungshistorie

Version	Datum	Name	Beschreibung
0.5	03.11.2022	BSI, Referat DI 27	Erste Kommentierungsrunde
0.7	06.03.2023	BSI, Referat DI 27	Zweite Kommentierungsrunde
0.9	04.12.2023	BSI, Referat DI 27	Version für die öffentliche Kommentierung
0.96	29.08.2025	BSI, Referat D 25	Fassung nach grundlegender Überarbeitung, Anpassung an mittlerweile bekannte Architektur des NOOTS; Version zur Kommentierung durch BVA
0.97	29.10.2025	BSI, Referat D 25	Version für die öffentliche Kommentierung

Tabelle 1: Versionshistorie

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: registermodernisierung@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2025

Danksagung

Das Bundesamt für Sicherheit in der Informationstechnik bedankt sich bei den vielen Organisationen, die bei der Erarbeitung dieser Technischen Richtlinie mit ihren Ansichten und Kommentaren tatkräftig mitgeholfen haben. Im Besonderen bedanken wir uns bei dem Bundesverwaltungsamt (BVA), der Föderalen IT-Kooperation (FITKO) sowie der Koordinierungsstelle für IT-Standards (KoSIT) für ihre sehr ausgiebige Unterstützung.

Inhalt

1	Einleitung.....	7
1.1	Thematische Einordnung.....	7
1.2	Zielgruppe	8
1.3	Aufbau der Technischen Richtlinie	8
1.4	Schlüsselwörter	8
2	Begriffsdefinitionen.....	10
3	Kommunikationsmodell	14
3.1	Allgemeines Kommunikationsmodell	14
4	Allgemeiner Anforderungskatalog.....	17
4.1	Allgemeine Anforderungen.....	17
4.2	Kommunikation über das NOOTS.....	18
5	Zentrale Komponenten des NOOTS.....	19
5.1	Abbildung des abstrakten Kommunikationsmodells	21
5.2	Protokollierung.....	21
5.2.1	Anforderungen an die Protokollierung	22
5.3	IAM für Behörden: Identifizierung und Authentifizierung technischer Komponenten.....	22
5.3.1	Identifizierung und Authentifizierung	23
5.4	Registerdatennavigation	24
5.4.1	Anforderungen an die Registerdatennavigation.....	24
5.5	Vermittlungsstelle: Abstrakte Berechtigungsprüfung.....	25
5.5.1	Anforderungen an die abstrakte Berechtigungsprüfung	25
5.6	Monitoring.....	26
6	IDNr.-Abruf	28
6.1	Fachspezifische Einführung.....	28
6.1.1	Kommunikationsmodell von XBasisdaten.....	28
6.1.2	Abbildung des abstrakten Kommunikationsmodells	29
6.2	Fachspezifische Anforderungen für XBasisdaten	30
6.2.1	Authentifizierung.....	30
6.2.2	Protokollierung.....	31
7	Sichere Anschlussknoten.....	33
7.1	Build-, Release- und Deploymentmanagement.....	33
7.2	Kryptographische Anforderungen.....	34
7.3	Nachrichtenvalidierung	35
7.4	Fehlerbehandlung.....	36
7.5	Sicherer Anschlussknoten für Data Consumer	36
7.6	Sicherer Anschlussknoten für Data Provider	37

Literaturverzeichnis	39
Abkürzungsverzeichnis.....	41

1 Einleitung

1.1 Thematische Einordnung

In der immer weiter voranschreitenden digitalisierten Welt steigt zunehmend auch das Interesse daran, die öffentlichen Verwaltungsleistungen digital erledigen zu können. Die Grundlage dafür bildet das Onlinezugangsgesetz (OZG). Darüber hinaus streben Bund, Länder und Kommunen die Umsetzung des sogenannten „Once-Only-Prinzips“ an. Dieses Prinzip soll es Bürgern bzw. Antragstellern ersparen, bereits an anderer Stelle in der öffentlichen Verwaltung zu ihnen vorliegende Informationen im Zuge eines Onlineantrages erneut angeben zu müssen. Dadurch können Anträge medienbruchfrei und digital vervollständigt werden, sodass auch das wiederholte Erfassen von Informationen durch die Behörde – bei entsprechender Zustimmung durch den Antragsteller oder rechtlicher Grundlage – entfällt. Im Rahmen des OZG 2.0 wird die gesetzliche Grundlage für diesen automatisierten Datenaustausch in Form einer Änderung des E-Government-Gesetzes (EGovG) geschaffen. Das technische Fundament hierfür bildet eine Modernisierung der Datenhaltung in den Behörden. Hierzu wurde am 6. April 2021 das Registermodernisierungsgesetz (RegMoG) verabschiedet, um die Modernisierung der Register in Bund, Ländern und Kommunen voranzutreiben. Dieses Gesetz führt eine neue Identifikationsnummer für natürliche Personen (IDNr.) ein, welche in die Stammdaten verschiedener Verwaltungsregister eingepflegt werden muss. Darüber hinaus wird für juristische Personen durch das Unternehmensbasisdatenregistergesetz (UBRegG) eine bundeseinheitliche Wirtschaftsnummer für Unternehmen (beWiNr) eingeführt, welche als Identifikationsnummer für Unternehmen dienen soll. Dies ermöglicht die Etablierung neuer Standards zur Kommunikation und Datenübermittlung zwischen Registern bzw. zwischen Registern und Behörden.

Zur Kommunikation zwischen den Registern und Onlinediensten wird gemäß NOOTS-Staatsvertrag (1) eine neuartige Kommunikationsinfrastruktur, das Nationale Once-Only-Technical-System (NOOTS), errichtet. Das NOOTS wird die Teilnehmenden unter Nutzung spezieller Sicherer Anschlussknoten (SAKs) miteinander vernetzen und stellt als Transportweg eine weitere technische Grundlage dar. Das NOOTS dient ferner der Erfüllung verschiedener rechtlicher Vorgaben wie der Abstrakten Berechtigungsprüfung im Sinne des Gesetzes zur Einführung und Verwendung einer Identifikationsnummer (IDNrG) sowie der Bereitstellung notwendiger Zentralsdienste zur Identifizierung oder zur Ermittlung der zuständigen nachweisliefernden Stellen. Die Verbindung zum europäischen Once-Only-Technical-System im Sinne der SDG-Verordnung (Verordnung (EU) 2018/1724 des Europäischen Parlaments und des Rates vom 2. Oktober 2018) erfolgt über eine Intermediäre Plattform.

Insbesondere der Übertragungsweg der Datenübermittlung im NOOTS stellt ein potentiell es Angriffsziel dar. Beispielsweise könnten Registerdaten abgefangen und/oder manipuliert werden oder verschiedene Registerdaten mithilfe der IDNr. widerrechtlich zusammengeführt werden. Daher ist es notwendig, entsprechende Sicherheitsmechanismen gegen solche Angriffe zu etablieren.

Ziel dieser Technischen Richtlinie (TR) ist es daher, Anforderungen zu definieren, sodass bei deren korrekter Umsetzung Angriffe auf die Kommunikation im NOOTS nicht erfolgreich sind und ein sicherer sowie nachvollziehbarer Datenaustausch gewährleistet ist. Grundlagen für die IT-Sicherheit der einzelnen Komponenten sind dem BSI-Grundsatz zu entnehmen. Diese Technische Richtlinie listet dementsprechend spezifische Anforderungen aus dem BSI-Grundsatz sowie darüber hinaus gehende Anforderungen auf. Des Weiteren wird angenommen, dass der Betreiber eines IT-Systems bereits notwendige betriebliche Maßnahmen, beispielsweise zur Sicherstellung eines hohen Verfügbarkeitsniveaus, getroffen hat.

Da der Datenaustausch über das NOOTS stets im Zusammenspiel mit weiteren Komponenten stattfindet, sind ergänzend zur vorliegenden Technischen Richtlinie zusätzliche Vorgaben zu beachten wie die Technische Richtlinie zum Portalverbund (TR-03172). Weitere Vorgaben für anzuschließenden Stellen werden als TR-03190 derzeit erarbeitet.

1.2 Zielgruppe

Diese TR richtet sich in erster Linie an die Entwickler und Betreiber der Komponenten des „Nationalen Once-Only Technical Systems“ (NOOTS). Ferner richtet sich die TR auch an die Betreiber und Entwickler der Anschlusssysteme an das EU-OOTS. Da einige in dieser Richtlinie formulierte Anforderungen nur durch das NOOTS und die angeschlossenen Systeme – wie Register, Onlinedienste und registerabfragende Behörden – gemeinsam umgesetzt werden können, sind diese Informationen auch für die entsprechenden Personengruppen relevant. Diese TR stellt jedoch keinesfalls eine vollständige Liste der Anforderungen an diese Systeme dar. Die IT-sicherheitstechnischen Anforderungen an das NOOTS angeschlossenen Systeme sind in der TR-03190 formuliert. Die IT-sicherheitstechnischen Anforderungen an das Datenschutzcockpit finden sich in der TR-03172 Portalverbund (2).

1.3 Aufbau der Technischen Richtlinie

Diese Technische Richtlinie besteht aus mehreren Kapiteln, die sich den verschiedenen, für die IT-Sicherheit relevanten Komponenten des NOOTS widmen. Zunächst werden allgemeine Anforderungen aufgelistet, die im Kontext der TR stets zu erfüllen sind. Darauf folgen fachspezifische Kapitel.

Um die Anforderungen der einzelnen Kapitel eindeutig unterscheiden zu können, wird jede Anforderung mit einer eindeutigen Nummer versehen, bestehend aus:

1. Einem Präfix zur Markierung des Dokumententeils, in dem die Anforderung enthalten ist, z.B. A für Allgemein oder XBd für XBasisdaten,
2. der Unterkapitelnummer und
3. einer fortlaufenden Nummer innerhalb des Unterkapitels, die ggf. weitere Untergliederungen erhält.

Enthält diese TR Verweise auf das IT-Grundschutz-Kompendium, so beziehen sich diese auf die Edition 2023 (3).

Die Technische Richtlinie repräsentiert den Stand der Technik und wird fortlaufend aktualisiert.

1.4 Schlüsselwörter

In der vorliegenden Technischen Richtlinie werden Anforderungen als Ausdruck normativer Festlegungen durch die in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS/MÜSSEN, DARF NICHT/DÜRFEN NICHT, SOLLTE/SOLLTEN entsprechend gekennzeichnet.

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um deutlich zu machen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf RFC 2119 (4).

MUSS/DARF NUR: Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).

DARF NICHT/DARF KEIN: Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).

SOLLTE: Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.

SOLLTE NICHT/SOLLTE KEIN: Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.

KANN

Dieser Ausdruck bedeutet, dass eine bestimmte Umsetzung gewählt werden kann. Diese muss allerdings angezeigt werden.

2 Begriffsdefinitionen

Im Rahmen dieser Technischen Richtlinie werden Begriffe verwendet, die wie folgt definiert werden:

Begriff	Definition
Basisdaten	Stammdatensatz über eine natürliche Person oder ein Unternehmen im Sinne des § 4 IDNrG oder § 3 UBRegG
Basisregister	Register, welches Basisdaten vorhält. Es existiert das Basisregister des BZSt für natürliche Personen sowie das Basisregister des StBA für Unternehmen.
Bundeseinheitliche Wirtschaftsnummer für Unternehmen (beWiNr)	Nummer, die einem Unternehmen nach § 2 UBRegG zugeordnet wird.
Data Consumer (DC)	Technisches System, das Nachweisdaten anfordert. Im Verantwortungsbereich des Data Consumers befindet sich ein sicherer Anschlussknoten (SAK) und ggf. ein Data Consumer Adapter (DCA).
Data Provider (DP)	Technisches System, das Nachweisdaten zum Abruf bereitstellt. Im Verantwortungsbereich des Data Providers befindet sich ein sicherer Anschlussknoten (SAK) und ggf. ein Data Provider Adapter (DPA).
Empfangssystem	Instanz, die Fachdaten empfängt. Im Falle einer versendeten Nachweisanfrage ist das Empfangssystem dasjenige, das die Anfrage empfängt, also ein Data Provider. Im Falle von versendeten Nachweisen ist das Empfangssystem der Data Consumer.
Ende-zu-Ende	Wird von „Ende-zu-Ende“ gesprochen, ist damit „von Sendesystem zu Empfangssystem“ gemeint. Bezogen auf die Architektur des NOOTS meint dies konkret „vom Sicherem Anschlussknoten des Data Consumers bis zum Sicherem Anschlussknoten des Data Providers“.
Fachdaten	Fachliche Daten; der genaue Aufbau dieses Nachrichtenformats wird durch das Protokoll (z.B. XBasisdaten) spezifiziert. Ein möglicher Inhalt dieser Fachdaten kann auch eine Anfrage sein mit dem Ziel, Daten abzurufen.
Fachnachricht	Nachricht, die die Fachdaten enthält; sie wird in der Regel als Teil einer Transportnachricht übertragen.
Fachverfahren	IT-gestützter Vorgang zur Bearbeitung eines Antrags durch die öffentliche Verwaltung im Kontext der Antragstellung gemäß OZG.
Fachsystem	Technisches System, beispielsweise ein Fachverfahren, Onlinedienst oder Register. Es kann als Sende- oder Empfangssystem auftreten.

Begriff	Definition
IAM für Behörden	Das IAM für Behörden dient als zentrale Identifizierungs- und Authentifizierungskomponente für technische Komponenten, die als „NOOTS-Teilnehmer“ am Datenaustausch über das NOOTS beteiligt sind.
Identitätsdatenabruf (IDA)	Verfahren zum Abruf der Identifikationsnummer und anderer Basisdaten aus der Steuer-ID-Datenbank des Bundeszentralamtes für Steuern.
Identifikationsnummer (IDNr.)	Die Identifikationsnummer nach § 139b Abgabenordnung. Wird nach Identifikationsnummerngesetz als zusätzliches Ordnungsmerkmal in dort angegebenen Registern eingeführt, um eine natürliche Person eindeutig zu identifizieren.
Intermediärsystem	Ein Intermediärsystem ist eine Instanz, die bei der Nachrichtenübermittlung auf der Transport-Anwendungsebene (OSI-Schicht 7) aktiv ist, also die damit verbundenen Metadaten verarbeitet und auf dieser Basis Mehrwertdienste zum Datentransport erbringt. Beispiele für Intermediärsysteme sind Loadbalancer, Firewalls, Web Application Firewalls oder Reverse Proxys, die sich im Netzwerk der NOOTS-Teilnehmer befinden. Die „Intermediäre Plattform“ zur Anbindung des NOOTS an das EU-OOTS ist hiervon als Architekturkomponente begrifflich abgegrenzt. Auch die Sicheren Anschlussknoten (SAKs) stellen kein Intermediärsystem dar, sondern sind Teil des Sende- bzw. Empfangssystems von Data Consumer bzw. Data Provider. Ebenso werden zentrale NOOTS-Komponenten wie das IAM für Behörden, das IDM für Personen, das IDM für Unternehmen und die Vermittlungsstelle (VS) hier nicht als Intermediärsysteme verstanden, da sie nicht dem Weiterleiten der Nachrichten dienen, sondern zentrale Funktionen des NOOTS erfüllen.
Metadaten	Daten, die mit den Fachdaten verbunden werden, um den korrekten Transport der Fachdaten zu gewährleisten; sie enthalten selbst keine Fachdaten. Metadaten lassen sich einerseits in fachliche Metadaten (z.B. Übermittlungszeitpunkt oder Empfängerinformationen) und technische Metadaten andererseits (z.B. IP-Adresse) unterscheiden. Im Rahmen der TR sind in der Regel fachliche Metadaten gemeint.
Monitoring-Zentralstelle	Es ist notwendig, dass im NOOTS an einer zentralen Stelle die Protokolleinträge der verschiedenen Komponenten gesammelt und ausgewertet werden, um verdächtige Aktivitäten zu erkennen und zeitnah reagieren zu können. Diese wird hier als Monitoring-Zentralstelle bezeichnet.

Begriff	Definition
Onlinedienst	Digitaler Service, um Verwaltungsleistungen zu beantragen. In der Regel werden die Eingaben an ein Fachverfahren weitergeleitet und dort verarbeitet. Im Kontext von NOOTS sind Onlinedienste Data Consumer (DC).
Register	Ein Register ist eine Komponente, mit der die Datenbestände in der öffentlichen Verwaltung elektronisch geführt werden. Im Rahmen dieser TR umfasst der Begriff „Register“ auch Spiegelregister oder Abrufportale, wenn diese bei Datenabrufen als Data Provider an die Stelle der eigentlichen Register treten.
Registermodernisierungsbehörde	Die Behörde, die gemäß Gesetz damit beauftragt wurde, den Identitätsdatenabruf bereitzustellen; aktuell ist dies das BVA.
Sicherer Anschlussknoten (SAK)	Die Sicheren Anschlussknoten sind Komponenten, die für den Anschluss der NOOTS-Teilnehmer (Data Consumer und Data Provider) an das NOOTS verwendet werden. Sie übernehmen Aufgaben bei der Kommunikation mit den zentralen NOOTS-Komponenten und der Prüfung eingehender Nachrichten und sind für die Ver- und Entschlüsselung zuständig. Sie werden von der Registermodernisierungsbehörde zur Verfügung gestellt, aber von den Data Consumern und Data Providern in Eigenverantwortung betrieben.
Sendesystem	Instanz, die eine Fachnachricht versendet. Wenn eine Nachweisanfrage versendet wird, ist das sendende System der Data Consumer. Werden Nachweise versendet, ist das sendende System der Data Provider.
Transportebene	Die Transportebene stellt eine Ebene dar, welche die Punkt-zu-Punkt-Kommunikation zwischen zwei miteinander verbundenen Systemen ermöglicht.
Transport-Anwendungsebene	Die Transport-Anwendungsebene (OSI-Schicht 7) ist technisch Teil der Anwendungsebene im ISO/OSI-Schichtenmodell. Sie erfüllt Mehrwertdienste für die Kommunikation (z.B. Postfach für asynchrone Kommunikation, Bestimmung des technischen Leitweges auf Basis einer fachlichen Adressierung, Weiterleitung von Nachrichten) und verarbeitet hierfür gegebenenfalls Metadaten. Beispiele für Kommunikationsprotokolle auf dieser Ebene sind eDelivery AS4, HTTPS in Verbindung mit Regelungen zur Ausgestaltung der Schnittstellen, OSCI-Transport oder X-Road.
Transportnachricht	Nachricht der Transport-Anwendungsebene (OSI-Schicht 7), welche die Fachnachricht enthält, sowie Metadaten, die für die Ausübung der Aufgaben der Transportebene notwendig sind. Der Aufbau der Nachricht wird durch das auf der Transport-Anwendungsebene verwendete Protokoll bestimmt.

Begriff	Definition
Transportverschlüsselung	Als Transportverschlüsselung bezeichnet man eine Verschlüsselung der Fachnachricht auf der Transportebene, beispielsweise mittels TLS.
NOOTS-Teilnehmer	Als Teilnehmer des NOOTS werden die über SAKs angeschlossenen Data Provider und Data Consumer bezeichnet.
Ende-zu-Ende-Verschlüsselung	Als Ende-zu-Ende-Verschlüsselung bezeichnet man eine Verschlüsselung der Fachnachricht, die gewährleistet, dass niemand außer dem Empfangs- und Sendesystem Kenntnis über den Inhalt der Nachricht erwerben kann. Insbesondere wird die Verschlüsselung der Fachdaten nicht an zwischengeschalteten Systemen aufgebrochen. Die „Enden“ dieser Verschlüsselung werden in den jeweiligen Unterkapiteln für die jeweilige Kommunikation genauer definiert.
Vermittlungsstelle (VS)	Die Vermittlungsstelle erfüllt als Autorisierungskomponente die Aufgabe, bei Nachweisabrufen eine abstrakte Berechtigungsprüfung durchzuführen.
XBasisdaten	Standard zum Abrufen von Basisdaten über natürliche Personen
XDatenschutzcockpit	Standard zum Abrufen von Protokollen aus Registern zwecks Darstellung im Datenschutzcockpit. Letzteres ist eine IT-Komponente, mit der sich natürliche Personen digitale Auskünfte anzeigen lassen können, welche Daten unter Verwendung ihrer persönlichen IDNr. zwischen öffentlichen Stellen ausgetauscht wurden.
XNachweis	Standard zum Abrufen von Nachweisen
XUnternehmen.Basisregister	Standard zum Abrufen von Basisdaten über Unternehmen

3 Kommunikationsmodell

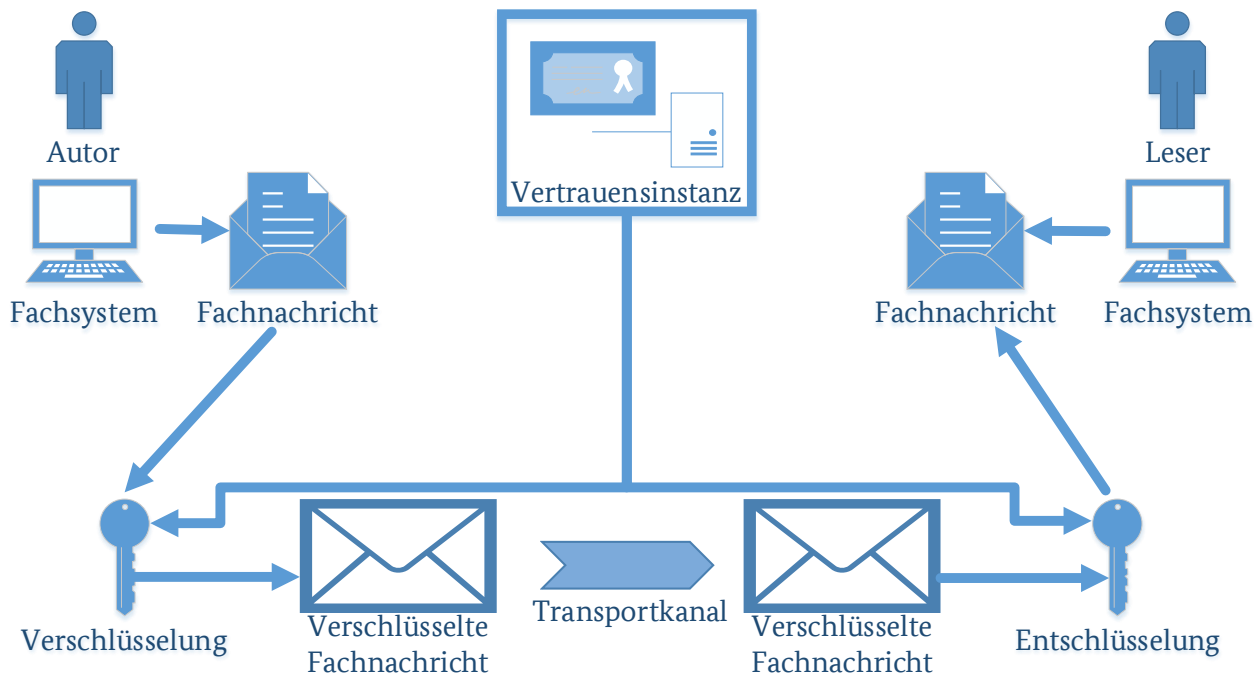
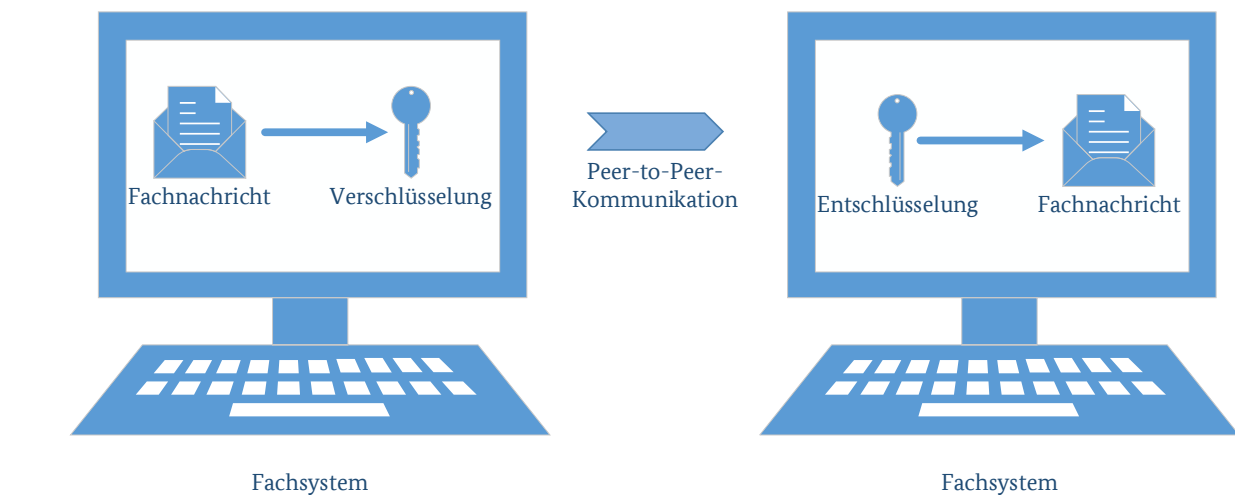


Abbildung 1: Allgemeines Kommunikationsmodell

3.1 Allgemeines Kommunikationsmodell

Abbildung 1 stellt ein abstraktes Modell zur Kommunikation zwischen einem Autor und einem Leser dar. Autor und Leser kontrollieren jeweils ein Fachsystem, welches die Erzeugung beziehungsweise die Verarbeitung der Fachnachricht übernehmen. Das Fachsystem des Autors stellt hierbei das Sendesystem dar. Das Fachsystem des Lesers nimmt die Rolle eines Empfangssystems ein. Beispiele für solche Systeme wären Nachweise anfordernde Data Consumer und beim Nachweisabruf angefragte Register. Da die Fachsysteme im Auftrag der eigentlich handelnden Personen bzw. fachlich verantwortlichen öffentlichen Stellen agieren, können sie letztlich als Autor und Leser betrachtet werden, auch wenn die Verantwortung für die Kommunikation an sich auf den Menschen zurückfällt. In der Praxis findet man oftmals auch den Fall, dass ein Fachsystem beispielsweise über eine Bedienungs Oberfläche fernbedient wird (z.B. Webapps). Welche konkreten Fachsysteme die Rolle des Autors oder Lesers einnehmen, wird durch die Fachstandards des jeweiligen Fachsystems definiert.

Zwischen den Fachsystemen von Autor und Leser existiert ein Transportkanal, welcher die Daten überträgt, ohne direkt die Inhaltsdaten selbst einsehen zu können. Im NOOTS dienen die Sicheren Anschlussknoten, die sich jeweils im Verantwortungsbereich von Sende- bzw. Empfangssystem befinden, als Start- und Endpunkte des Transportkanals. Transport und Fachlichkeit sind also getrennt, sodass nur der Autor (bzw. sein Fachsystem) für die Inhaltsnachricht zuständig ist und deren formale Korrektheit gewährleistet. Zum Transport wird die verschlüsselte Inhaltsnachricht in eine Transportnachricht eingebettet, in der auch die für den Transport notwendigen Metadaten hinterlegt sind. Für den Aufbau des Transportkanals, über den die Transportnachricht versendet wird, kommen verschiedene Möglichkeiten in Betracht. Zwei Beispiele werden in der Abbildung 2 sowie der Abbildung 3 dargestellt.



Hinweis: Oft wird auf eine Verschlüsselung auf dem Fachsystem verzichtet und stattdessen eine transportverschlüsselte Peer-to-Peer-Kommunikation verwendet. Aufgrund der direkten Kommunikation wirkt die Transportverschlüsselung faktisch wie eine Ende-zu-Ende-Verschlüsselung.

Abbildung 2: Darstellung des abstrakten Kommunikationsmodells anhand einer Peer-to-Peer-Kommunikation

Abbildung 2 zeigt eine sogenannte „Peer-to-Peer“-Kommunikation. Hierbei kommunizieren die Fachsysteme unmittelbar miteinander. Hierfür ist eine direkte Verbindungsmöglichkeit über ein Netzwerk erforderlich. Erfolgt eine Kommunikation auf diese Weise, so müssen die Fachsysteme alle Aufgaben des Transports in sich vereinen. Das heißt, Autor und Leser müssen Aufgaben des Transportkanals mit erfüllen. Hierzu gehört beispielsweise, dass der Autor selbst bereits die technischen Parameter für den Leitweg zum Leser ermittelt. Dafür ist allerdings eine strikte Trennung zwischen Fach- und Transportnachricht nicht mehr zwangsläufig erforderlich. Beispielsweise würde eine Verschlüsselung der Transportnachricht automatisch auch als Ende-zu-Ende-Verschlüsselung wirken, denn es existieren hier keine Zwischensysteme, die die Transportnachricht auswerten müssten.

Im Gegensatz zu einer direkten Kommunikation zweier Systeme, die sich im gleichen Netz befinden, ist die Kommunikation im NOOTS jedoch in der Regel durch mehrere Netzübergänge geprägt. An diesen Netzübergängen sind zur Absicherung häufig Firewalls oder andere Intermediärsysteme vorhanden, die ein Aufbrechen der Transportverschlüsselung erzwingen.

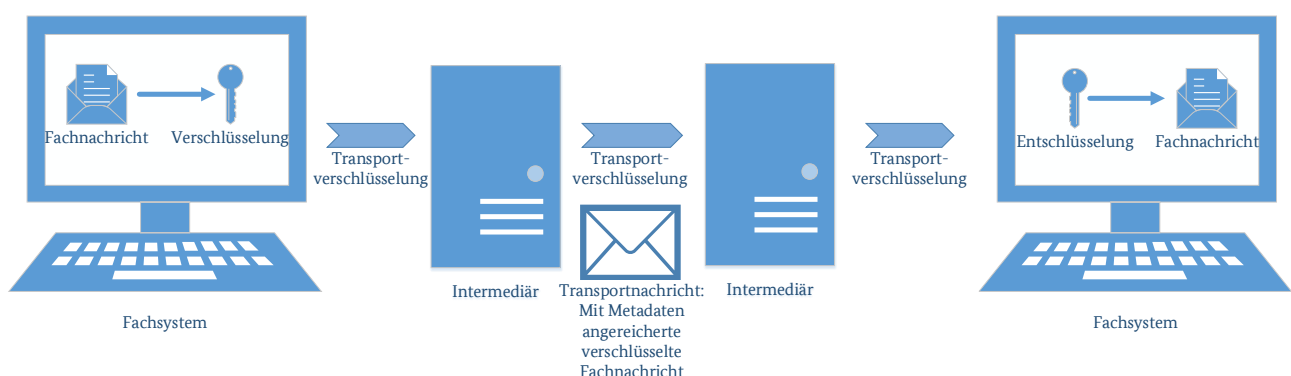


Abbildung 3: Darstellung des abstrakten Kommunikationsmodells anhand einer Kommunikation über Intermediäre

Abbildung 3 zeigt eine Kommunikation unter Nutzung von Intermediären. Um die korrekte Weiterleitung der Nachricht zu gewährleisten, ist hierbei in der Regel die Anreicherung der Fachdaten mit Metadaten notwendig. Diese Metadaten werden gemeinsam mit der verschlüsselten Fachnachricht in der Transportnachricht übertragen. Die Metadaten werden von den Intermediären ausgewertet und zur Bestimmung des weiteren Transportpfades benutzt. Die hierbei notwendige Punkt-zu-Punkt-Sicherheit

zwischen zwei Systemen wird von dem System errichtet, welches die Nachricht zu einem anderen System weiterleitet. Das andere System dagegen stellt sicher, dass es Transportnachrichten entgegennehmen, verarbeiten und gegebenenfalls korrekt weiterleiten kann oder zumindest dem nächsten System auf dem Transportweg zur Verfügung stellen kann. Da die Fachnachricht selbst aber in der Darstellung vor der Übermittlung durch den Autor verschlüsselt wird, erhalten die Intermediäre keinen Einblick in die Fachnachricht selbst.

Der Autor ist für die Erzeugung und Absendung der Inhaltsnachricht zuständig, ist also Ursprung der Datenübermittlung. Der Endpunkt der Datenübermittlung ist der Leser als finaler Adressat der Datenübermittlung. Der Leser einer Nachricht wird durch den Autor festgelegt. Sobald der Leser eine Antwort auf eine Nachricht generiert, sind die Rollen in Bezug auf die Antwort getauscht, der vormalige Leser ist also Autor der Antwort, der vorige Autor Leser der Antwort.

Der Leser stellt sicher, dass er in der Lage ist, Nachrichten zu empfangen. Darüber hinaus stellt er sicher, dass die notwendigen Informationen zur Errichtung einer Ende-zu-Ende-Sicherheit vorliegen und kommuniziert hierzu mit der Vertrauensinstanz, deren Rolle durch die zentralen NOOTS-Komponenten bzw. die zugrundeliegende PKI erfüllt wird.

Die Vertrauensinstanz ist zuständig, allen an der Kommunikation beteiligten Instanzen die Möglichkeit zu geben, die Ende-zu-Ende-Sicherheit sicherzustellen. Das bedeutet, dass die Vertrauensinstanz die Identität aller an der Kommunikation beteiligter Instanzen beglaubigt. Hierbei muss die Vertrauensinstanz eine für alle Kommunikationsparteien einheitliche und gleichermaßen vertrauenswürdige Stelle sein. Es muss eine Möglichkeit geben, eine Beglaubigung zur Überprüfung einer Identität zu erhalten. Dies erfolgt klassischerweise durch Zertifikate oder durch die Nutzung zentraler Identitätsdienste.

Alle Instanzen haben die gemeinsame Verantwortung, die Einhaltung der Regeln - hier: die Anforderungen der vorliegenden technischen Richtlinie - durchzusetzen. Das bedeutet insbesondere auch, dass Verstöße entsprechend der vorgegebenen Regeln behandelt werden müssen, sobald sie einer Partei bekannt werden.

4 Allgemeiner Anforderungskatalog

Die Verantwortlichen und Betreiber der zentralen Transportinfrastruktur NOOTS müssen die hier aufgelisteten Anforderungen beachten. Teilweise muss die Umsetzung dieser Anforderungen in den angebundenen Systemen oder unter Mitwirkung der angebundenen Systeme erfolgen. Dieser Anforderungskatalog stellt dennoch ausdrücklich keine abschließende Liste der Anforderungen an angebundene Systeme dar, wie man sie in TR-03190 findet, sondern richtet sich an die Registermodernisierungsbehörde und ihre Dienstleister als Verantwortliche für die zentralen NOOTS-Komponenten sowie für die Entwicklung und Bereitstellung der SAKs.

4.1 Allgemeine Anforderungen

- [A.1.1] Die BSI-Standards 200-1 (5), 200-2 (6) und 200-3 (7) oder die Vorgaben der ISO/IEC 27001 (8) MÜSSEN in der jeweils geltenden Fassung umgesetzt werden. Als Mindestniveau MUSS die Standard-Absicherung für den betreffenden Informationsverbund gewählt werden. Das IT-Grundschutz-Kompendium MUSS in der aktuellen Version verwendet werden.
- [A.1.2] Der BSI-Standard 200-4 (9) oder die Vorgaben der ISO-Norm 22301:2019 (10) MUSS in der jeweils geltenden Fassung umgesetzt werden. Schnittstellen zu angeschlossenen Diensten SOLLTEN berücksichtigt werden. Es MÜSSEN im Rahmen des Notfallmanagements Maßnahmen getroffen werden, wie mit Sicherheitsvorfällen umzugehen ist.
- [A.1.3] Alle zentralen Komponenten des NOOTS MÜSSEN vor der Inbetriebnahme mindestens mittels eines Penetrationstests bzw. Webchecks überprüft werden. Dieser MUSS spätestens nach 3 Jahren oder bei größeren Änderungen wiederholt werden.
- [A.1.4] Vor Inbetriebnahme MUSS jede NOOTS-Komponente einem externen Code-Audit unterzogen werden.
- [A.1.5] Die Verantwortlichen MÜSSEN die Verfügbarkeitsanforderungen an die zentralen Komponenten des NOOTS dokumentieren und die Architektur der beteiligten Systemkomponenten daran ausrichten.
- [A.1.6] Bei der Ermittlung der Verfügbarkeitsanforderung MÜSSEN die potentielle Nutzerbasis sowie eventuelle Stichtage und Fristen imungsverfahren berücksichtigt werden, die zu Lastspitzen bzw. erhöhten Zugriffszahlen auf den Dienst führen können. Es SOLLTEN Lasttests durchgeführt werden, um die Skalierbarkeit und Stabilität der Infrastruktur zu gewährleisten.
- [A.1.7] Im Sicherheitskonzept MUSS der Reaktionsprozess bei Bekanntwerden einer Schwachstelle auf Basis ihrer Kritikalität klar definiert sein. Der Reaktionsprozess MUSS allen Beteiligten bekannt sein. Der Weiterbetrieb des NOOTS bei bekannter Schwachstelle DARF NICHT länger sein als die im Sicherheitskonzept auf Basis der Kritikalität definierte Übergangsfrist. Es MUSS eine security.txt nach RFC 9116 (11) implementiert und regelmäßig aktualisiert werden.
- [A.1.8] OPS.1.1.3.A15 („Regelmäßige Aktualisierung von IT-Systemen und Software“) und CON.8.A20 („Überprüfung von externen Komponenten“) des IT-Grundschutz-Kompendiums MÜSSEN eingehalten werden. Insbesondere MÜSSEN an der Kommunikation beteiligte Systeme, die erforderliche Aktualisierungen nicht durchgeführt haben, erkannt und ausgeschlossen werden.
- [A.1.9] Die Produktivumgebung MUSS von weiteren Betriebsumgebungen getrennt betrieben werden. Zusätzlich SOLLTEN weitere Betriebsumgebungen für verschiedene Zwecke voneinander getrennt betrieben werden (z. B. Entwicklungsumgebung, Testumgebung, Stagingumgebung).
- [A.1.10] Es muss ein Software-Bill-of-Materials (SBOM) gemäß TR-03183-2 (12) erstellt werden.
- [A.1.11] Eingesetzte (Dritt-) Software MUSS in einer Version verwendet werden, die mit Sicherheitsupdates versorgt wird. Wenn für die Anwendung relevante Schwachstellen in verwendeter Software bekannt werden, MÜSSEN die zugehörigen Sicherheitsupdates kurzfristig eingespielt werden. Die Umsetzungszeit MUSS der Kritikalität und Ausnutzbarkeit der Schwachstelle entsprechend angemessen gewählt werden. Software, die nicht länger vom Hersteller oder Entwickler gewartet wird, DARF NICHT verwendet werden.
- [A.1.12] Ein Prozess für den Umgang mit Responsible-Disclosure-Meldungen MUSS etabliert sein.

[A.1.13] Das Prinzip der Datensparsamkeit MUSS eingehalten werden: Jede Komponente des NOOTS darf nur die Daten einsehen und verarbeiten, die zur Erfüllung der ihr zugewiesenen Aufgaben nötig sind.

4.2 Kommunikation über das NOOTS

- [A.2.1] Alle am Nachweisabruf beteiligten technischen Systeme MÜSSEN die Identität ihrer Kommunikationspartner anhand mehrerer, voneinander unabhängiger Faktoren überprüfen. Einen dieser Faktoren kann das Zugriffstoken der Identifizierungs- und Authentifizierungskomponente des NOOTS darstellen.
- [A.2.2] Schlägt die Überprüfung der Teilnahmeberechtigung, Identifizierung oder Authentifizierung eines Kommunikationspartners fehl, DARF die von diesem Kommunikationspartner erhaltene Nachricht NICHT verarbeitet werden.
- [A.2.3] Sowohl Data Consumer (DC) als auch Data Provider (DP) MÜSSEN für jede Kommunikation über das NOOTS einen sicheren Anschlussknoten (SAK) verwenden.
- [A.2.4] Für jedes an der Kommunikation teilnehmende System MUSS ein Verweis auf eine Stelle, die zur manuellen Klärung von Fehlern oder zur Meldung von Fehlern kontaktiert werden kann, vorliegen und innerhalb der Kommunikationsinfrastruktur allgemein bekannt sein.
- [A.2.5] Die Log-Dateien als auch die Log-Level, die den Detailgrad der Log-Dateien festlegen, MÜSSEN mit geeigneten Maßnahmen vor Manipulation geschützt werden.

5 Zentrale Komponenten des NOOTS

Um Nachweisabrufe über das NOOTS zu ermöglichen, ist ein hoher Grad an Interoperabilität zwischen dem Onlinedienst oder Fachverfahren einerseits und dem Register andererseits erforderlich. Zu diesem Zweck wurde durch das Bundesverwaltungsamt (BVA) als betriebsverantwortliche Stelle des NOOTS der Standard XNachweis herausgegeben. Der Standard legt verbindlich die Datenstruktur für Nachweisabrufe innerhalb des NOOTS fest. Der Standard orientiert sich hierbei an den Technischen Entwurfsdokumenten (TDDs) des europäischen Once-Only-Technical-Systems (EU-OOTS).

Im NOOTS läuft die Kommunikation entsprechend der Abbildung 4 ab. Danach wird das NOOTS als Netzwerk mehrerer „Sicherer Anschlussknoten“ (SAKs) errichtet. Diese SAKs spannen ein Verbindungsnetz (VN) auf. An den SAKs angebunden werden die eigentlichen Endpunkte der Kommunikation, nämlich einerseits der Data Consumer (DC) als Fachsystem, welches einen Nachweis anfordert, und der Data Provider (DP) als Fachsystem, das einen Nachweis anbieten kann. Diese Nachweise können beispielsweise in maschinenlesbarer Form vorliegende Dokumente sein. Perspektivisch ist allerdings der Umbau der Akteure so vorgesehen, dass nur noch einzelne Auszüge aus Einzeldokumenten oder gar Atteste darüber, ob eine bestimmte Aussage (z.B. „minderjährig“) zutrifft, übermittelt werden müssen.

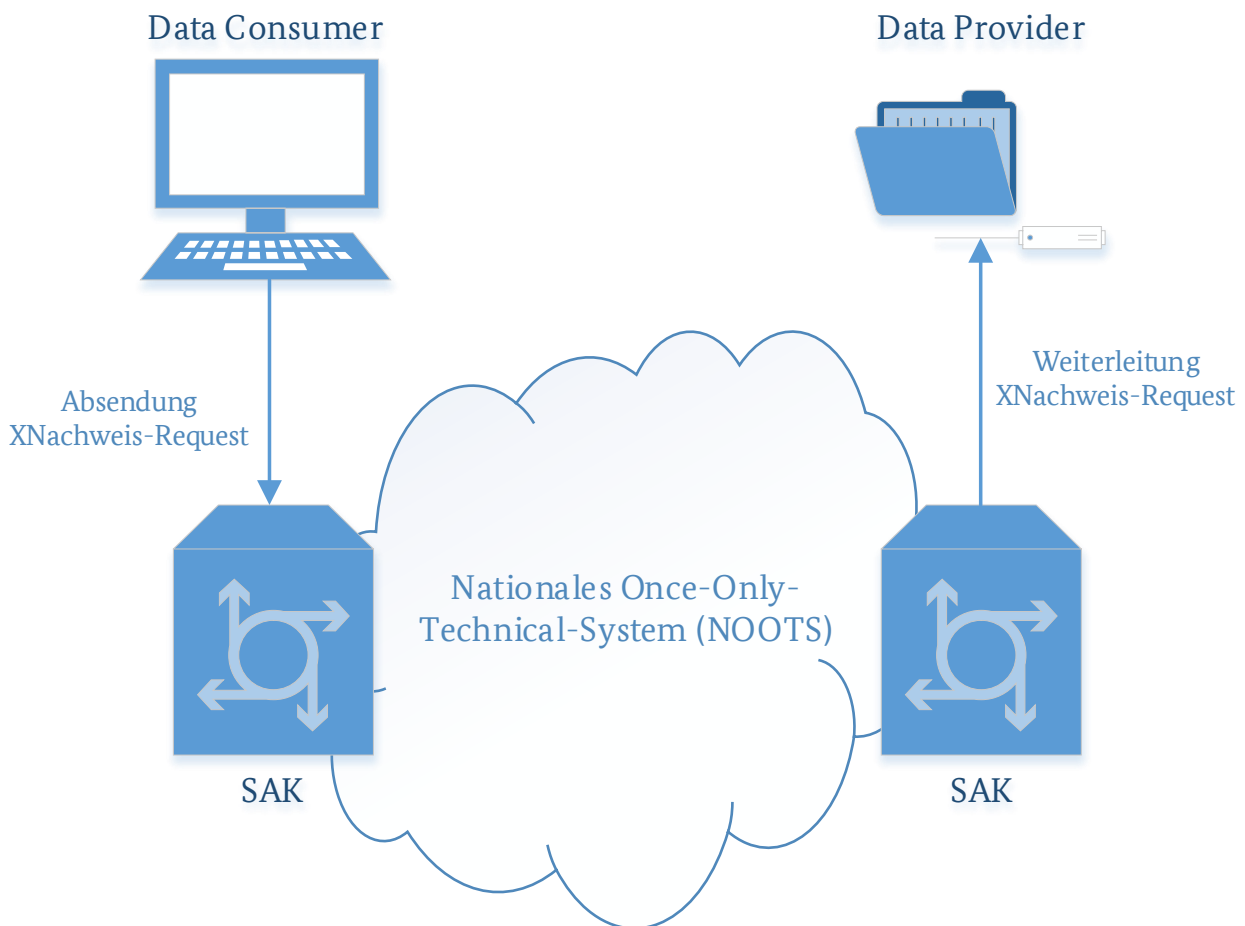


Abbildung 4: Kommunikationsbeziehung beim Nachweisabruf

Da sich manche Data Provider in besonders gesicherten Netzen befinden, in denen speziellen Vorgaben für den Datentransfer gelten, ist als alternative Anbindungsmöglichkeit auch Long Polling zwischen SAK und Data Provider möglich, wie in Abbildung 5 dargestellt. Hierbei agiert der DP als "aktiver Empfänger", d.h. er sendet wiederholt Anfragen an den SAK-DP ob neue Nachweis-Anfragen dort eingegangen sind. Der SAK-

DP antwortet bei Vorliegen einer Nachweis-Anfrage mit dem Weiterleiten dieser. Andernfalls terminiert der SAK-DP die Verbindung nach einer vordefinierten Wartezeit und der DP sendet eine neue Anfrage.

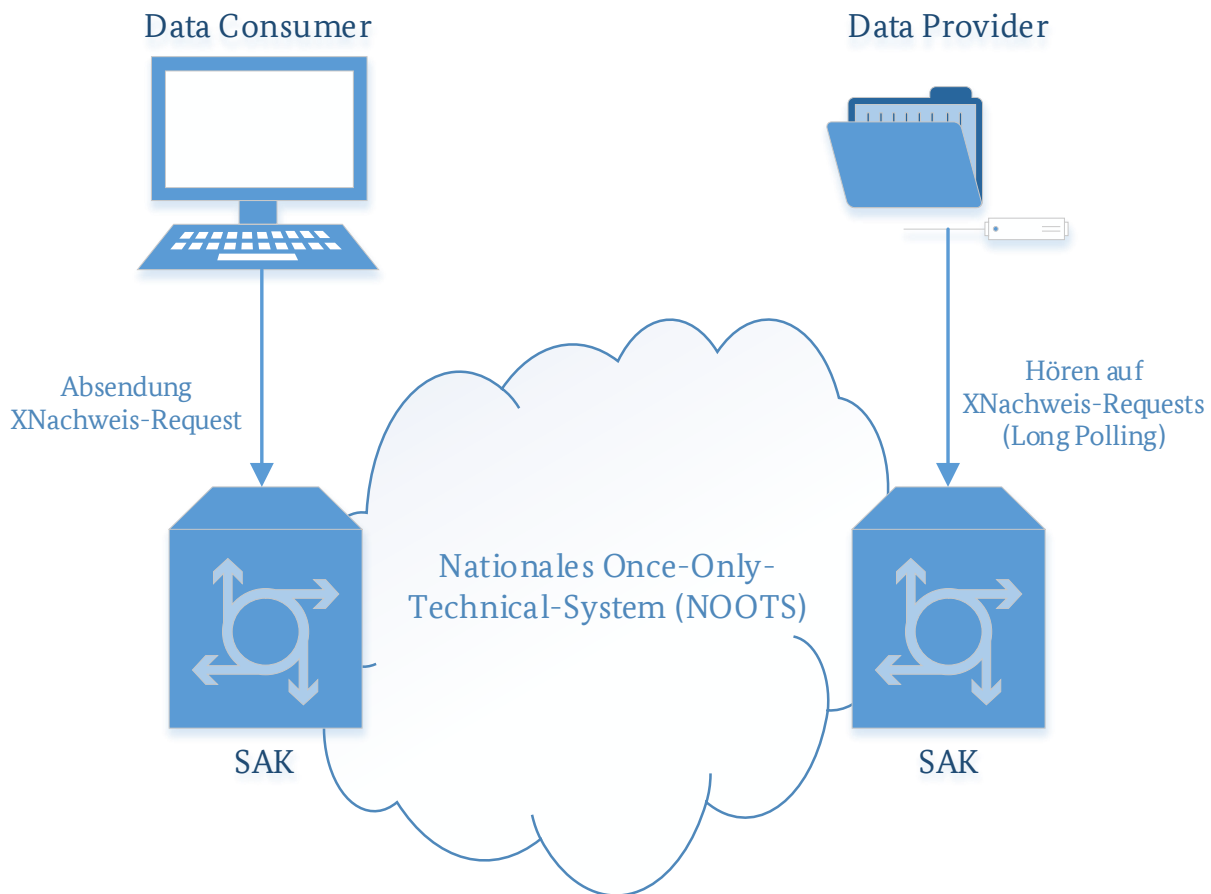


Abbildung 5: Nachweisabruf mittels Long Polling

Zur Durchführung des Nachweisabrufs sind zusätzlich zu den SAKs verschiedene Zentralkomponenten notwendig. Hierzu gehören das IAM für Behörden, welches der Identifizierung und Authentifizierung der angebundenen Systeme dient, die Registerdatennavigation (RDN) zur Bestimmung des zuständigen Data Providers, sowie die Vermittlungsstelle (VS), die eine abstrakte Berechtigungsprüfung durchführt. Zusätzlich zu diesen drei Komponenten findet im NOOTS ein zentrales Monitoring statt. IT-sicherheitstechnische Anforderungen an diese vier Komponenten werden im vorliegenden Kapitel aufgeführt.

Damit IAM für Behörden, Registerdatennavigation (RDN) sowie Vermittlungsstelle (VS) ihrer jeweiligen Aufgabe nachkommen können, müssen sie mit Daten über angeschlossene NOOTS-Teilnehmer (Data Consumer und Data Provider, DC und DP) sowie die zwischen ihnen bestehenden Abrufberechtigungsbeziehungen versorgt werden. Diese Daten sollen über ein Datenmanagementsystem (DAMAS) zur Verfügung gestellt werden, das seinerseits auf die aktive Befüllung durch betriebs- und fachverantwortliche Stellen angewiesen ist. Da dieses Pflegesystem nicht direkt an der Datenübertragung beteiligt ist, wird es in der vorliegenden Technischen Richtlinie nicht explizit behandelt.

Darüber hinaus ist für den Betrieb des NOOTS eine Methode zur Abfrage der zu einer natürlichen Person gehörigen IDNr. notwendig. Da dieser Abruf nur im Zusammenspiel mit dem Basisregister des Bundeszentralamts für Steuern realisierbar ist und hierfür ein eigenes Datenaustauschformat etabliert wurde, wird dieser Abruf gesondert in Kapitel 6 behandelt. Da der Datenaustausch unter Verwendung der IDNr. gesetzlich besonders geschützt wird, muss das NOOTS an das Datenschutzcockpit (DSC) angeschlossen sein, damit es den Bürgerinnen und Bürgern ermöglicht, Datenaustausche zu ihrer IDNr.

nachzuvollziehen. IT-sicherheitstechnische Anforderungen an diese Komponente finden sich in der TR-03172 zum Thema Portalverbund.

Ebenfalls essentiell für den Datenaustausch im NOOTS sind Sichere Anschlussknoten (SAKs). Diese stellen die Endpunkte der Kommunikation über das NOOTS dar und befinden sich in der Betriebsverantwortung der Data Consumer (DC) und Data Provider (DP). IT-Sicherheitsanforderungen an Sichere Anschlussknoten sind im letzten Kapitel dieser Technischen Richtlinie zu finden. Hierbei ist zu beachten, dass die vorliegende technische Richtlinie lediglich Anforderungen formuliert, die bei der Erstellung, Auslieferung und für die Software der SAKs gelten. Anforderungen an den Betrieb und die Betriebsumgebung der SAKs sowie weitere Anforderungen, die DC und DP beim Anschluss an das NOOTS mit Hilfe der SAKs erfüllen müssen, finden sich in der TR-03190, die Anschlussbedingungen an das NOOTS auflistet, sowie für Onlinedienste in der TR-03172 zum Thema Portalverbund.

5.1 Abbildung des abstrakten Kommunikationsmodells

Die Abbildung der Rollen des abstrakten Kommunikationsmodells (Abbildung 1) auf die Kommunikation im Standard XNachweis ist wie folgt:

- Bei einer Nachweisanfrage ist der Data Consumer (DC) Autor der Nachricht, der Data Provider (DP) Leser der Nachricht. Bei der Antwort auf diese Anfrage sind die Rollen vertauscht.
- Die SAKs liegen im Verantwortungsbereich von DC bzw. DP und stellen die Endpunkte der Ende-zu-Ende-Verschlüsselung dar.
- Auf dem Kommunikationsweg können sich weitere Systemkomponenten befinden, beispielsweise Web Application Firewalls oder Reverse Proxies in den Netzen der beteiligten Kommunikationspartner.
- Weitere zentrale Dienste des NOOTS sind indirekt am Nachweisabruf beteiligt, da sie vor dem eigentlichen Nachweisabruf aufgerufen worden sein müssen, um entsprechende Berechtigungstoken zu erhalten, die beim Nachweisabruf mitgeliefert werden müssen.
- Falls der Data Consumer ein Online-Dienst ist, so erfolgt der Nachweis-Abruf über ein synchrones Kommunikationsmuster, d.h. auf eine Nachweis-Anfrage erfolgt in derselben Sitzung eine Antwort des SAK-DP. Für die Kommunikation von Behörde zu Behörde über das NOOTS kann alternativ ein asynchrones Kommunikationsmuster verwendet werden, bei dem die Nachweis-Antwort zeitversetzt zur Anfrage bereitgestellt wird.
- Die Vertrauensinstanz wird im Falle eines Nachweisabrufs durch mehrere Systeme und Prozesse repräsentiert. So sorgt die Wurzelzertifizierungsstelle als zugrundeliegender Vertrauensanker der Zertifikate für Sicherheit. Konkret wird die Teilnahmeberechtigung der beteiligten IT-Komponenten über das IAM für Behörden geprüft. Zusätzlich wird die abstrakte Rechtmäßigkeit der Kommunikation durch die Vermittlungsstelle (VS) sichergestellt. Darüber hinaus ist die Authentifizierung der Nutzer und somit eine wichtige Voraussetzung für die konkrete Abrufberechtigung durch eine Authentifizierung am Data Consumer (DC) oder eine Nachauthentifizierung im NOOTS nachprüfbar.

5.2 Protokollierung

Zur Sicherstellung einer gesetzeskonformen, transparenten und nachvollziehbaren Datenverarbeitung sowie zur Möglichkeit der Detektion von sicherheitskritischen Ereignissen ist die Führung von Protokollen und Logs erforderlich. Diese Richtlinie betrachtet hierbei fokussiert Protokolle, welche in erster Linie der Informationssicherheit dienen. Folgende Anforderungen sind an die Protokollierung in den Zentralkomponenten IAM für Behörden, RDN und VS zu richten. Spezielle Anforderungen und Protokollierungssituationen sind in den darauffolgenden Unterkapiteln zu finden.

5.2.1 Anforderungen an die Protokollierung

- [Z.1.1] Sofern die gesetzlichen Anforderungen des § 9 IDNrG bei der Datenübermittlung zutreffen, MUSS ein dem § 9 IDNrG entsprechendes Protokoll geführt werden. Genaue Vorgaben ergeben sich aus den gesetzlichen Vorschriften und sind nicht Teil dieser Richtlinie.
- [Z.1.2] Es MUSS ein Protokoll über alle betriebs- und sicherheitsrelevanten Ereignisse geführt werden. Dies schließt die Protokollierung von Änderungen am Datenbestand der Zentralkomponenten des NOOTS mit ein. Dabei MUSS der Mindeststandard des BSI zur Protokollierung und Detektion von Cyberangriffen (13) umgesetzt werden.
- [Z.1.3] Es MUSS ein Übermittlungsprotokoll geführt werden, aus dem sich organisatorische Aspekte der Datenübermittlung transparent nachvollziehen lassen. Die inhaltliche Ausgestaltung des Protokolls ergibt sich aus der Rolle in der Datenübermittlung und wird im jeweiligen Unterkapitel näher spezifiziert.
- [Z.1.4] Zur Führung des Protokolls MUSS der BSI-IT-Grundschutzbaustein OPS.1.1.5 („Protokollierung“) umgesetzt werden. Hierbei MÜSSEN neben den Basis-Anforderungen auch die Standard-Anforderungen sowie die Anforderung OPS.1.1.5.A11 („Steigerung des Protokollierungsumfangs“) des IT-Grundschutz-Kompodiums umgesetzt werden. Die weiteren Anforderungen für erhöhten Schutzbedarf SOLLTEN umgesetzt werden, sofern hierfür im Rahmen der Risikoanalyse ein Bedarf gesehen wird.
- [Z.1.5] Die IDNr. gemäß IDNrG DARF NICHT im Rahmen dieses Protokolls gespeichert werden. Andere identifizierende personenbezogene Daten sowie die bundeseinheitliche Wirtschaftsnummer für Unternehmen gemäß URegG und andere Identifikationsnummern nach § 3 Abs. 3 URegG DÜRFEN NICHT im Rahmen des Protokolls gespeichert werden.
- [Z.1.6] Die einzelnen Übermittlungsprotokolle MÜSSEN bei einer Monitoring-Zentralstelle regelmäßig gesammelt und ausgewertet werden.
- [Z.1.7] Falls die Auswertung ein mögliches sicherheitsrelevantes Ereignis ergibt, MUSS die Monitoring-Zentralstelle in Zusammenarbeit mit den an der Kommunikation beteiligten Systemen das Ereignis überprüfen, möglicherweise existente Meldepflichten erfüllen und gegebenenfalls Maßnahmen zur Lösung des Problems koordinieren. Anforderung DER.2.1.A17 („Nachbereitung von Sicherheitsvorfällen“) des IT-Grundschutz-Kompodiums MUSS umgesetzt werden.

5.3 IAM für Behörden: Identifizierung und Authentifizierung technischer Komponenten

Zu Beginn jedes Nachweisabrufes über das Nationale Once-Only Technical System (NOOTS) müssen sich DCs zunächst vom IAM für Behörden ein Zugriffstoken für ihre Teilnahme am Abrufprozess über NOOTS ausstellen lassen. Dem IAM für Behörden kommt also eine zentrale Rolle zu, berechnete Teilnehmer zu identifizieren und zu authentifizieren. Diese Funktion kann das IAM für Behörden mit Hilfe der Daten ausführen, die im Datenmanagementsystem (DAMAS) hinterlegt sind. In diesem Sinne stellt das IAM für Behörden in der Zero-Trust-Architektur gemeinsam mit dem Pflegesystem DAMAS einen Policy Decision Point dar.

Ebenso kann das IAM für Behörden als Policy Enforcement Point wirken und einen NOOTS-Teilnehmer kurzfristig vom Daten-Austausch ausschließen, falls dieser beispielsweise im Rahmen des Monitorings durch verdächtige Aktivitäten aufgefallen ist. Dieser Ausschluss wird erreicht, indem das Zugriffstoken nicht ausgestellt wird, was einen zeitnahen, Schaden begrenzenden und dennoch leicht wieder aufzuhebenden Reaktionsmechanismus darstellt.

Die folgenden Anforderungen sind vom IAM für Behörden umzusetzen. Sie sind teilweise nur im Zusammenspiel mit Systemen außerhalb des Verantwortungsbereichs des NOOTS erfüllbar. Das NOOTS muss in diesen Fällen die Umsetzung unterstützen und ermöglichen. Gleichzeitig stellt dies keine abschließende Liste an Anforderungen an die entsprechenden Systeme außerhalb des NOOTS dar.

5.3.1 Identifizierung und Authentifizierung

- [Z.2.1] Das IAM für Behörden (IAMfB) als die zentrale Komponente des NOOTS zur Identifizierung und Authentifizierung der am Datenaustausch über das NOOTS teilnehmenden datenabrufenden Komponenten MUSS von allen anderen Komponenten des NOOTS sowie von DCs und DP's und ihren SAKs zuverlässig identifiziert und authentifiziert werden können. Hierfür muss die Anforderung ORP.4 des IT-Grundschutz-Kompendiums inklusive der Anforderungen für hohen Schutzbedarf beachtet werden.
- [Z.2.2] Die privaten Schlüssel der zentralen Identifizierungs- und Authentifizierungskomponente des NOOTS MÜSSEN auf Hardware Security Modules erzeugt und gespeichert werden. Für die Verwaltung des kryptografischen Materials MUSS mindestens das Security Level 2 gemäß der Key Lifecycle Security Requirements (14) eingehalten werden.
- [Z.2.3] Das IAM für Behörden als zentrale Identifizierungs- und Authentifizierungskomponente des NOOTS MUSS registrierte Data Consumer des NOOTS und ihre SAKs gemäß der Anforderung ORP.4 des IT-Grundschutz-Kompendiums zuverlässig identifizieren, authentifizieren und ihnen ein Zugriffstoken als Nachweis über ihre Teilnahmeberechtigung ausstellen. Diese Teilnahmeberechtigung MUSS zeitlich befristet und mit einer Nonce versehen sein sowie vom IAM für Behörden gesiegelt werden.
- [Z.2.4] Die kryptografischen Vorgaben des BSI gemäß TR-02102-1 MÜSSEN vom IAM für Behörden umgesetzt werden.
- [Z.2.5] Bei jeder Kommunikation mit dem IAM für Behörden MUSS eine mTLS-Verschlüsselung verwendet werden, die den Anforderungen der TR-02102-2 (15) genügt.
- [Z.2.6] Es MUSS sichergestellt werden, dass nur DC an einem Nachweisaustausch über NOOTS teilnehmen können, die vor Beginn des Nachweisaustausches dem IAM für Behörden bekannt sind.
- [Z.2.7] Das IAM für Behörden oder der SAK des IAM für Behörden oder das Application-Level-Gateway (ALG) des IAM für Behörden MUSS prüfen, dass jede Anfrage eines DC von dem ihm zugeordneten SAK gesiegelt wurde, dass der entsprechende Zeitstempel nicht abgelaufen ist und die Nonce der Anfrage noch nicht behandelt wurde.
- [Z.2.8] Es DARF NICHT möglich sein, mit veralteten Versionen eines SAK über die Übergangszeit hinaus am IAM für Behörden ein Token über die Teilnahmeberechtigung als NOOTS-Teilnehmer zu erlangen. Die Übergangszeit MUSS entsprechend der Kritikalität des Updates gewählt sein und MUSS entsprechend an alle NOOTS-Teilnehmer kommuniziert werden.
- [Z.2.9] Bei einer von einem SAK eingehenden Anfrage an das IAM für Behörden MUSS dieses (beispielsweise über die Siegelung der Anfrage) die betriebsverantwortliche Stelle des SAKs ermitteln und überprüfen, dass diese existent und aktuell zur Kommunikation über das NOOTS berechtigt ist.
- [Z.2.10] Das IAM für Behörden MUSS die anfragende IT-Komponente identifizieren und überprüfen, dass diese existent und aktuell zur Kommunikation über das NOOTS berechtigt ist. Ferner MUSS das IAM für Behörden sicherstellen, dass die anfragende IT-Komponente und die ermittelte betriebsverantwortliche Stelle zusammengehören.
- [Z.2.11] Bei einer eingehenden Anfrage an das IAM für Behörden MUSS dieses die fachverantwortliche Stelle der Anfrage ermitteln und überprüfen, dass diese existent ist und aktuell zur Teilnahme am NOOTS berechtigt ist.
- [Z.2.12] Jeder DC MUSS über eine für die Anbindung an NOOTS dedizierte digitale Signatur gemäß TR-02102-1 (16) eindeutig identifizierbar sein.
- [Z.2.13] Das IAM für Behörden MUSS die verwendeten Noncen bis zur Ablaufzeit der dazugehörigen Zeitstempel speichern, um Replay-Angriffe zu verhindern.
- [Z.2.14] Zur Registrierung neuer DCs und DP's im NOOTS sowie zur Pflege und Aktualisierung derer Daten SOLLTEN Pflegesysteme verwendet werden, die vom IAM für Behörden getrennt sind, um die Angriffsfläche auf dieses zentrale Authentifizierungssystem zu minimieren.
- [Z.2.15] Das IAM für Behörden MUSS in regelmäßigen Abständen mit aktuellen Daten der registrierten DCs versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass neu

hinzugekommene DC zeitnah verwendet werden können sowie für nicht mehr verwendete DC zeitnah keine Zugriffstoken mehr ausgestellt werden können.

- [Z.2.16] Es MUSS die Möglichkeit geben, dass das IAM für Behörden in Notfällen kurzfristig einem bestimmten DC keine weiteren Zugriffstoken ausstellt, wenn dieser DC sich auffällig verhält und dies über das Monitoring oder andere Wege bekannt geworden ist.
- [Z.2.17] Ist eine Überprüfung der Teilnahmeberechtigung oder Identifizierung oder Authentifizierung fehlgeschlagen, DARF KEIN Zugriffstoken ausgestellt werden. Der Vorgang MUSS protokolliert werden und der Protokolleintrag der Monitoring-Zentralstelle, an der die Protokolleinträge in der Gesamtschau ausgewertet werden, zur Verfügung gestellt werden. Es SOLLTE eine Fehlermeldung an den Kommunikationspartner gesendet werden, dessen Teilnahmeberechtigung oder Identität oder Authentizität nicht bestätigt werden konnte. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.2.18] Auch jedes erfolgreiche Ausstellen eines Zugriffstokens MUSS unter Angabe des verwendeten SAKs sowie der fach- und betriebsverantwortlichen Stelle protokolliert werden und dieses Protokoll ebenfalls der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden.

5.4 Registerdatennavigation

Die Registerdatennavigation (RDN) dient dem Auffinden des zuständigen DP für einen gegebenen Nachweisabruf. Sie wird vom SAK des DC aufgerufen, nachdem sich dieser bereits am IAM für Behörden eine Teilnahmeberechtigung in Form eines Zugriffstokens für das NOOTS ausstellen lassen hat. Hierbei erfragt der SAK des DC bei der RDN den zuständigen Dataprovider für einen angefragten Nachweistyp. Die RDN beantwortet diese Anfrage mit dem Zuständigkeitstoken, in dem u.a. die Information über Name und ID des zuständigen Data Providers gesiegelt vorliegen. Des Weiteren ruft der SAK des DC bei der RDN die Verbindungsdaten des benötigten Data Providers ab. Die RDN beantwortet diese Anfrage mit den in dem Verbindungstoken gesiegelten Verbindungsdaten. Die für diese Funktionen notwendige Datengrundlage bezieht die RDN aus dem DAMAS, das auch das IAM für Behörden und die Vermittlungsstelle (VS) speist.

Indem die RDN überprüft, dass eine an sie gestellte Anfrage vorschriftsgemäß erfolgt, übernimmt sie in der Zero-Trust-Architektur die Rolle eines Policy Decision Points. Im Falle einer Abschaltung einzelner Komponenten, beispielsweise aufgrund von Auffälligkeiten im Monitoring, übernimmt die RDN auch die Rolle eines Policy Enforcement Points, indem sie die entsprechenden Verbindungsdaten zurückhält.

5.4.1 Anforderungen an die Registerdatennavigation

- [Z.3.1] Die RDN MUSS vor der Ermittlung der technischen Adressierungsparameter des gesuchten Registers nachprüfen, dass der anfragende SAK des DC ein Zugriffstoken übermittelt hat, das zeitlich gültig ist und das ein verifizierbares Siegel besitzt.
- [Z.3.2] Falls die Verifikation der Abfrageberechtigung des anfragenden Systems gemäß [Z.3.1] negativ ausfällt, DARF die RDN KEINE Verbindungsparameter zurückliefern. Sie SOLLTE eine Fehlermeldung zurücksenden. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.3.3] Die RDN SOLLTE ihre Aufgabe erfüllen, ohne Einblick in die konkrete Nachweisanfrage zu erhalten, soweit sie ihre Aufgabe auch ohne diese Informationen erfüllen kann.
- [Z.3.4] Im Falle einer erfolgreichen Verifikation der Abfrageberechtigung des anfragenden Systems gemäß [Z.3.1] sowie erfolgreicher Ermittlung des gesuchten DP und dessen Verbindungsparameter MUSS die RDN die zurückzuliefernden Informationen siegeln. Die kryptografischen Vorgaben des BSI gemäß TR-02102-1 MÜSSEN hierfür beachtet werden.
- [Z.3.5] Bei der Kommunikation mit der RDN MUSS eine TLS-Verschlüsselung gemäß TR-02102-2 verwendet werden.
- [Z.3.6] Falls die Abfrageberechtigung gemäß [Z.3.1] verifiziert werden konnte, aber der gesuchte DP bzw. dessen Verbindungsparameter nicht geliefert werden können, SOLLTE die RDN eine Fehlermeldung zurücksenden.

- [Z.3.7] Zur Hinterlegung der Zuständigkeiten und Verbindungsparameter der DPs im NOOTS SOLLTE ein Pflegesystem verwendet werden, das von der RDN getrennt ist.
- [Z.3.8] Die RDN MUSS in regelmäßigen Abständen mit aktuellen Daten der registrierten DP versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass neu hinzugekommene DP zeitnah verwendet werden können sowie dass für nicht mehr verwendete DP zeitnah keine Zuständigkeiten und Verbindungsparameter mehr herausgegeben werden.
- [Z.3.9] Im Falle einer vom Monitoring detektierten Auffälligkeit bei einem der DP SOLLTE die RDN das notfallmäßige kurzfristige Ausschließen des betroffenen DP aus dem NOOTS unterstützen, indem es diesem DP bzw. einem für ihn agierenden SAK keine Daten über DPs und insbesondere keine Verbindungsparameter mehr liefert.
- [Z.3.10] Die RDN MUSS sowohl erfolgreiche als auch abgelehnte Anfragen und Anfragen, bei denen die gesuchten Zuständigkeiten oder Verbindungsparameter nicht ermittelt werden konnten, protokollieren und diese Protokolle der Monitoring-Zentralstelle zur Auswertung zur Verfügung stellen. Zu protokollieren sind mindestens der Zeitpunkt der Anfrage, anfragender SAK und zugehöriger DC sowie angefragter DP und, wenn zutreffend, den Ablehnungsgrund der Anfrage.

5.5 Vermittlungsstelle: Abstrakte Berechtigungsprüfung

Die Vermittlungsstelle (VS) ist eine zentrale Komponente des NOOTS, die eine abstrakte Berechtigungsprüfung durchführt. Gesetzlich vorgeschrieben ist sie für Nachweisabrufe unter Verwendung der IDNr. Sie wird im NOOTS im Sinne einer umfassenden Absicherung für alle nationalen Nachweisabrufe – nicht nur solche unter Verwendung der IDNr. – eingesetzt und prüft im Zusammenspiel mit dem IAM für Behörden und dem SAK des DP, dass der anfragende DC die grundsätzliche Berechtigung besitzt, bei dem angefragten DP den angefragten Nachweistyp abzurufen. In diesem Sinne stellt sie einen weiteren Policy Decision Point in der Zero-Trust-Architektur dar. Bei erfolgreicher Überprüfung dieser abstrakten Berechtigung zum Nachweisabruf sendet die VS zur Bestätigung das sog. Abruftoken zurück. Die konkrete Berechtigung der abrufenden Person oder Behörde zum Abruf eines bestimmten Datensatzes wird hingegen nicht von der VS geprüft, sondern liegt im Aufgabenbereich des DP.

5.5.1 Anforderungen an die abstrakte Berechtigungsprüfung

- [Z.4.1] Die Vermittlungsstelle (VS) als die zentrale Komponente des NOOTS zur Autorisierung von Nachweisabrufen MUSS von allen anderen Komponenten des NOOTS sowie von DCs und DPs und ihren SAKs zuverlässig identifiziert und authentifiziert werden können. Hierfür muss die Anforderung ORP.4 des IT-Grundschutz-Kompendiums inklusive der Anforderungen für hohen Schutzbedarf beachtet werden. Die privaten Schlüssel der VS MÜSSEN auf Hardware Security Modules erzeugt und gespeichert werden.
- [Z.4.2] Vor jedem Nachweisabruf unter Verwendung der IDNr. MUSS eine abstrakte Berechtigungsprüfung unter Einbeziehung der VS gemäß IDNrG §7 durchgeführt werden. Hierbei DARF die VS NICHT Einblick in die Inhaltsdaten der Nachweisanfrage erhalten.
- [Z.4.3] Vor jedem Nachweisabruf ohne Verwendung der IDNr. SOLLTE eine abstrakte Berechtigungsprüfung durchgeführt werden. Hierzu MUSS die VS prüfen, ob der anfragende DC zum Datenabruf beim angefragten DP berechtigt ist. Hierbei DARF die VS NICHT Einblick in die Inhaltsdaten der Nachweisanfrage erhalten.
- [Z.4.4] Die VS MUSS die Teilnahmeberechtigung des anfragenden DC nachprüfen. Das entsprechende Zugriffstoken MUSS bezüglich Zeitstempel und Siegelung des IAM für Behörden geprüft werden.
- [Z.4.5] Falls das Zugriffstoken des anfragenden DC nicht gültig ist, DARF die VS KEINE Berechtigungsprüfung durchführen und kein entsprechendes Abruftoken zurücksenden. Sie SOLLTE eine Fehlermeldung zurücksenden. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.4.6] Zur Hinterlegung der Abrufberechtigungen der DCs bei den jeweiligen DPs über das NOOTS SOLLTE ein Pflegesystem verwendet werden, das von der VS getrennt gepflegt wird.

- [Z.4.7] Die VS MUSS in regelmäßigen Abständen mit aktuellen Berechtigungsinformationen der registrierten DCs und DPs versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass bei neu hinzugekommenen Berechtigungen zeitnah ein Nachweisabruf über das NOOTS ermöglicht wird sowie dass auf Grundlage von veralteten Berechtigungsdaten zeitnah keine Abruftoken der VS mehr ausgestellt werden.
- [Z.4.8] Bei erfolgreicher Verifizierung der Teilnahmeberechtigung des anfragenden Systems und erfolgreicher abstrakter Berechtigungsprüfung MUSS die VS ein Abruftoken ausstellen und dem SAK des anfragenden DC zur Verfügung stellen. Dieses Abruftoken muss zeitlich befristet gültig sein, den Hashwert der Nachweisabfrage enthalten und von der VS gesiegelt werden. Der Vorgang MUSS protokolliert und der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden. Die kryptografischen Vorgaben des BSI gemäß TR-02102-1 MÜSSEN bei der Siegelung beachtet werden.
- [Z.4.9] Bei der Kommunikation mit der VS MUSS eine TLS-Verschlüsselung gemäß TR-02102-2 verwendet werden.
- [Z.4.10] Schlägt die abstrakte Berechtigungsprüfung fehl, DARF KEIN Berechtigungstoken ausgestellt werden. Der Vorgang MUSS protokolliert werden und der Protokolleintrag der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden. Es SOLLTE eine Fehlermeldung an den SAK des anfragenden DC gesendet werden. Diese Fehlermeldung DARF KEINE Rückschlüsse auf die Gründe für die Ablehnung zulassen, um ein Herantasten an zulässige Kommunikationspartner zu erschweren.

5.6 Monitoring

Auf Basis der Protokollierung durch die Komponenten des NOOTS ist es notwendig, eine aktive Detektion möglicher Angriffe durchzuführen. Dazu dient das Monitoring aktueller potentiell sicherheitsrelevanter Ereignisse. Hierbei sind die folgenden Anforderungen umzusetzen:

- [Z.5.1] Anforderung DER.1.A17 „Automatische Reaktion auf sicherheitsrelevante Ereignisse“ (einschließlich der dort erwähnten SOLLTE-Anforderungen) des IT-Grundschutz-Kompendiums oder eine andere Maßnahme mit ähnlicher Sicherheitswirkung MUSS umgesetzt werden.
- [Z.5.2] Es MÜSSEN Meldekettens für die Meldung von Sicherheitsvorfällen etabliert werden.
- [Z.5.3] Es MUSS einen Prozess zur gleichzeitigen Notabschaltung aller zentralen NOOTS Komponenten geben.
- [Z.5.4] Es MUSS eine Monitoring-Zentralstelle etabliert werden, die die von den verschiedenen NOOTS-Komponenten erzeugten und bereitgestellten Protokolle auswertet und bei Auffälligkeiten automatisiert reagiert.
- [Z.5.5] Es MUSS ein Rate Limiting auf Grundlage der fachlich zu erwartenden Last der Systemanfragen eingeführt werden, das für alle DCs und DPs den Empfang von Nachrichten begrenzt (Datenvolumen/Zeiteinheit). Alternativ DARF eine Angriffsdetektion mit Hilfe eines sich selbst auf Muster trainierenden Systems (künstlicher Intelligenz) durchgeführt werden, durch die auf das starre Rate-Limiting nach genauer Abwägung aller Risiken verzichtet werden kann, sobald das entsprechende System die zu erwartenden Lasten sicher erlernt hat.
- [Z.5.6] Wird ein Rate-Limiting verwendet und wird die im Rate-Limiting definierte Last überschritten, so SOLLTEN Systeme mit Fehlerhäufung automatisch temporär ausgeschlossen werden. Es MUSS ein Prozess für die manuelle Sperrung und Entsperrung von Komponenten etabliert werden.
- [Z.5.7] Insbesondere MUSS ein Prozess etabliert werden, der es
- a) dem IAM für Behörden erlaubt, bei Auffälligkeiten (wie beispielsweise einer Häufung abgelehnter Anfragen eines DC innerhalb einer kurzen Zeitspanne), die einen bestimmten DC betreffen, diesen mit sofortiger Wirkung automatisiert von der weiteren Teilnahme am NOOTS auszuschließen, indem keine Zugriffstoken mehr ausgestellt werden;
 - b) der RND erlaubt, bei Auffälligkeiten, die einen bestimmten DP betreffen, diesen mit sofortiger Wirkung automatisiert von der weiteren Teilnahme am NOOTS auszuschließen, indem die entsprechenden Verbindungsparameter nicht mehr zur Verfügung gestellt werden.

Diese Maßnahme MUSS einen vorher definierten Prozess auslösen, bei dem eine manuelle Klärung und gegebenenfalls eine Aufhebung der Sperre oder eine Anordnung weiterer Maßnahmen erfolgt.

[Z.5.8] Wird ein Rate-Limiting verwendet und die in [Z.5.5] definierte Menge überschritten, so DARF NUR dann das Empfangssystem dem Sendesystem wieder antworten, nachdem die Verantwortlichen beider Systeme durch manuelle Prüfung festgestellt haben, dass die Nachrichten rechtmäßig übermittelt wurden. In diesem Fall KANN das Empfangssystem für dieses Sendesystem die Menge zulässiger Nachrichten pro Zeiteinheit je nach Notwendigkeit temporär oder dauerhaft erhöhen.

6 IDNr.-Abruf

6.1 Fachspezifische Einführung

Im Rahmen der Registermodernisierung wurde durch das IDNrG festgelegt, dass die vorige Steuer-Identifikationsnummer zu einer allgemeinen Identifikationsnummer (IDNr.) ausgebaut wird. Ziel ist die Erleichterung der eindeutigen Identifizierung natürlicher Personen mithilfe eines allgemeinen Ordnungskriteriums. Dadurch können Nachweise aus anderen Registern im Sinne des Once-Only-Prinzips einfacher abgerufen werden. Allerdings erfordert die Einführung der IDNr. einen zusätzlichen Dienst, der einerseits ermöglicht, vertrauenswürdig die IDNr. einer Person zu ermitteln und andererseits zu einer IDNr. die Basisdaten einer Person zu erhalten. Für diese Zwecke sieht das IDNrG die Einrichtung eines Identitätsdatenabrufs (IDA) vor. Dieser ermöglicht den Abruf der IDNr. und ggf. weiterer Basisdaten einer Person sowie die Aktualisierung ihrer Daten durch registerführende Stellen gemäß § 6 Abs. 1 i.V. m. § 2 IDNrG sowie den Abruf der IDNr. und ggf. weiterer Basisdaten durch berechnete andere öffentliche Stellen (u.a. das Datenschutzcockpit) zur Erbringung von Verwaltungsleistungen nach dem OZG gemäß § 6 Abs. 2 IDNrG.

Der Ablauf des Datenabrufs wird durch § 6 sowie § 7 IDNrG genauer spezifiziert.

XBasisdaten (17) ist der Standard zum Abruf von Basisregisterdatensätzen über natürliche Personen gemäß § 7 Abs. 1 IDNrG. Da es sich hierbei um personenbezogene Daten handelt, wurde in der XBasisdaten-Verordnung festgelegt, dass für die Kommunikation unter Verwendung von XBasisdaten besonders gesicherte verwaltungseigene Netze zu nutzen sind oder anderweitig ein Sicherheitsniveau für einen hohen Schutzbedarf sichergestellt wird. Die hier formulierten Anforderungen sind auch für die Anwendung innerhalb besonders gesicherter verwaltungseigener Netze geeignet.

6.1.1 Kommunikationsmodell von XBasisdaten

Der Abruf der Basisdaten erfolgt ausgehend von einer berechtigten Stelle über die IDA-Komponente der Registermodernisierungsbehörde (RMB). IDA selbst speichert dabei keine Daten, sondern ruft diese anhand der IDNr. aus der IDNr.-Datenbank des Bundeszentralamts für Steuern (BZSt) ab. Demzufolge kann die Kommunikation mit IDA in drei Kommunikationsbeziehungen aufgeteilt werden, wie in Abbildung 7 dargestellt:

- 1) Kommunikation Registerführende Stelle – IDA
- 2) Kommunikation Öffentliche Stelle bzw. Onlinedienst – IDA
- 3) Kommunikation IDA – BZSt

Die Kommunikationsbeziehungen 1) und 2) beziehen sich auf die in Abschnitt 6.1 beschriebenen Vorgänge. Die Kommunikationsbeziehung 3) stellt den Abruf der Basisdaten beim Register des BZSt durch das IDA-Verfahren dar. Diese Kommunikationsbeziehung ist nicht Gegenstand der in dieser TR formulierten Anforderungen.

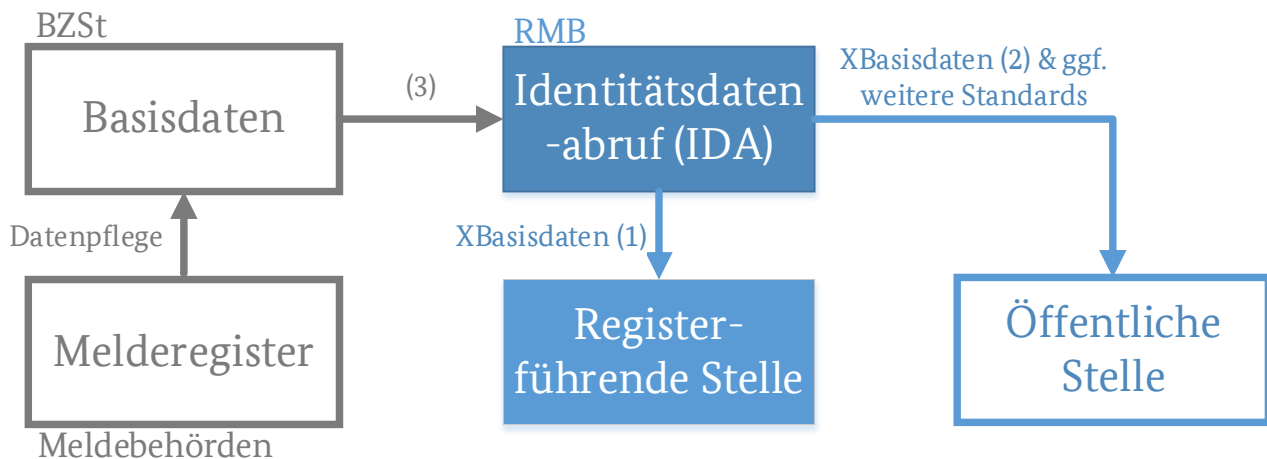


Abbildung 6: Kommunikationsbeziehungen des Identitätsdatenabrufs

6.1.2 Abbildung des abstrakten Kommunikationsmodells

Für die Kommunikation unter Nutzung des Standards XBasisdaten sind laut seiner Spezifikation drei verschiedene technische Übermittlungsverfahren vorgesehen:

1. XTA 2 in Verbindung mit OSCI-Transport
2. XTA 2 in Verbindung mit AS4 Profile von ebMS 3.0 in der jeweils geltenden Fassung sowie
3. HTTP-Schnittstellen über REST oder SOAP.

Die drei technischen Übermittlungsverfahren unterscheiden sich in der Art und Weise des Verbindungsaufbaus insofern, als dass bei den Varianten 1 und 2 eine nachrichtenorientierte Verbindung unter Nutzung von Intermediären erfolgt, während Variante 3 eine direkte Verbindungssitzung herstellt. Varianten 1 und 2 entsprechen also eher einer in der Abbildung 3 dargestellten Art der Kommunikation, während die Variante 3 eher der Abbildung 2 entspricht.

Bei den Varianten 1 und 2 lässt sich das abstrakte Kommunikationsmodell wie folgt auf das konkrete technische Übermittlungsverfahren abbilden:

- Sendesystem der Kommunikation ist das Fachsystem, welches die XBasisdaten-Abfrage erzeugt und abschickt. Dazu gehört beispielsweise ein Register bei der Erstbefüllung der IDNr. oder ein Onlinedienst, der die IDNr. einer Person für einen Nachweisabruf benötigt.
- Die Kommunikation läuft im Allgemeinen über zwei Intermediärsysteme ab. Diese sind bei Variante 1 die OSCI-Transport-Server, bei Variante 2 die AS4-Access-Points, die in beiden Fällen die Nachricht weiterübermitteln und an das IDA zustellen.
- Empfangssystem der Kommunikation ist das IDA-Verfahren.
- Eine Antwort ist faktisch wie eine unabhängige Nachricht in die Gegenrichtung zu behandeln, die Rollen wechseln hierbei.

Bei der Variante 3 dagegen unterscheidet sich die Abbildung, da keine Intermediärsysteme in dem Sinne existieren:

- Sendesystem der Kommunikation ist das Fachsystem, welches die XBasisdaten-Abfrage erzeugt und abschickt.
- Für die Kommunikation werden keine Intermediärsysteme verwendet. Stattdessen baut das Fachsystem unmittelbar mit dem IDA eine direkte Kommunikationssitzung auf. Da hier keine Intermediärsysteme existieren, ist eine dedizierte Ende-zu-Ende-Verschlüsselung entbehrlich, da die von HTTPS bereitgestellte Transportverschlüsselung aufgrund der fehlenden Intermediären unmittelbar auch wie eine Ende-zu-Ende-Verschlüsselung wirkt.

- Empfangssystem der Kommunikation ist das IDA-Verfahren. Da die TR eine Ende-zu-Ende-Verschlüsselung fordert, ist hierbei der Verschlüsselungskanal erst im organisatorischen Bereich des IDA zu terminieren, beispielsweise an einem selbstbetriebenen Gateway.
- Eine Antwort erfolgt über die aufgebaute Kommunikationssitzung. Das bedeutet auch, dass dem IDA-Verfahren als Sendesystem der Antwort beim Empfang die Prüfung obliegt, ob die vom Empfänger aufgebaute Kommunikationssitzung den Anforderungen der TR entspricht, indem beispielsweise nur nach der TR zulässige kryptographische Algorithmen für die Kommunikation zugelassen werden. Dadurch kann die Sitzung als Rückkanal wiederverwendet werden, ohne gegen die Anforderungen der TR zu verstoßen.

6.2 Fachspezifische Anforderungen für XBasisdaten

Zusätzlich zu den in Kapitel 4 genannten Anforderungen sind folgende Anforderungen zu erfüllen:

6.2.1 Authentifizierung

Zum Schutz des Basisregisters vor unzulässigen Zugriffen ist es notwendig, den Zugriff auf den Identitätsdatenabruf auf Instanzen zu beschränken, welche tatsächlich berechtigt sind, auf Daten aus dem Basisregister zuzugreifen.

6.2.1.1 Anforderungen bezüglich der öffentlichen Stelle

Das IDNrG sieht hierfür vor, dass sich die anfragende Stelle (also die öffentliche Stelle mit Abrufberechtigung im Sinne des Gesetzes) gegenüber der RMB authentisiert und auf dieser Basis eine Autorisierung erfolgt. Um dies sicherzustellen, sind folgende Anforderungen zu berücksichtigen:

- [XBd.1.1] Das Enrolment im Sinne der TR-03107-1 (18) MUSS mindestens mit substantiellem Vertrauensniveau erfolgen.
- [XBd.1.2] Die Identifizierung im Sinne der TR-03107-1 (18) MUSS mindestens mit substantiellem Vertrauensniveau erfolgen.
- [XBd.1.3] Wird das Authentisierungssystem nicht durch die RMB selbst betrieben, so MUSS durch technische Maßnahmen sichergestellt werden, dass tatsächlich ein von der RMB als vertrauenswürdig angesehenes System verwendet wurde.
- [XBd.1.4] Die RMB MUSS, bevor sie ein Abrufersuchen einer anfragenden Stelle beantwortet, zunächst durch technische Maßnahmen sicherstellen, dass eine Prüfung der Zugriffs- und Abrufberechtigung des Sendesystems durchgeführt wurde (Autorisierung). Wurde die Prüfung nicht durch die RMB selbst durchgeführt, MUSS die Prüfung durch einen aus Sicht der RMB vertrauenswürdigen Anmeldedienst erfolgt sein, und durch technische Maßnahmen MUSS sich die RMB vergewissern können, dass die Anmeldung tatsächlich bei einem vertrauenswürdigen Anmeldedienst erfolgt ist.
- [XBd.1.5] Für die Verwaltung des kryptografischen Materials MUSS mindestens das Security Level 2 gemäß der Key Lifecycle Security Requirements (14) umgesetzt werden.
- [XBd.1.6] Die Autorisierung MUSS auf Basis der im Rahmen der Identifizierung festgestellten Identität und ggf. hinterlegten Vertreterregelungen erfolgen.
- [XBd.1.7] Das Autorisierungssystem MUSS ein effektives Berechtigungsmanagement implementieren und durchsetzen. Insbesondere SOLLTE über das Rechte- und Rollenmanagement das Rate-Limiting im Sinne des Rahmendokuments parametrisiert sowie die Teilmenge der Basisdaten festgelegt werden, auf welche der Autor zugreifen darf (z.B. nur IDNr., nur IDNr. und Straße oder Ähnliches).
- [XBd.1.8] Kryptografisches Material MUSS bezüglich der Gültigkeit der daran gebundenen Identität verifiziert werden. Hierzu MÜSSEN die Vorgaben der TR-03116-4 (19) beachtet werden, insbesondere ist das Gültigkeitsdatum und ein möglicher Rückruf zu überprüfen.

6.2.1.2 Anforderungen bezüglich der konkreten Person

Das IDNrG erlaubt Abrufe nicht nur zur automatisierten Pflege der öffentlichen Register, sondern auch einzelne Abrufe von Nachweisen durch öffentliche Stellen zur Erbringung von Verwaltungsleistungen nach dem Onlinezugangsgesetz (OZG) sowie Abrufe einzelner Nachweise durch Onlinedienste, ebenfalls zur Erbringung von Verwaltungsleistungen, angestoßen durch die betroffene Person selbst oder einen Vertreter dieser Person. In der Regel können alle diese Abrufe konkreten Personen zugeordnet werden. Dies gilt auch bei Abrufen durch öffentliche Stellen, da diese meist von einem konkreten Mitarbeiter gestellt werden und zur Bearbeitung der Anfrage ein Abrufersuchen notwendig ist. Die Möglichkeit dieser Abrufe ist aber gleichzeitig besonders sicherheitsrelevant, da sie die Gefahr des unberechtigten Zugriffs auf das IDA-Verfahren beispielsweise über eine nicht ausreichend gesicherte öffentliche Stelle ermöglichen könnte. Zur Vermeidung dieses Risikos ist es sinnvoll, perspektivisch zusätzlich zu der abrufenden Stelle auch die Person zu autorisieren, die den Abruf konkret angestoßen hat. Hierzu dienen folgende Anforderungen:

- [XBd.2.1] Zusätzlich zu der durch das IDNrG geforderten Prüfung, ob die öffentliche Stelle zum Abruf berechtigt ist, SOLLTE eine konkrete Prüfung der Abrufberechtigung durchgeführt werden. Eine konkrete Prüfung der Abrufberechtigung erfüllt folgende Anforderungen:
- a) Das anfragende System MUSS dem IDA zur Prüfung der konkreten Abrufberechtigung einen überprüfbaren Nachweis über die Identität der Person, die persönlich den Abruf bei der abrufenden Stelle angewiesen hat, vorlegen oder alternativ zu einem von der RMB bestimmten vertrauenswürdigen Authentifizierungsdienst weiterleiten, sodass sie sich direkt gegenüber dem IDA authentisiert.
 - b) Das Autorisierungssystem MUSS prüfen, ob die anfragende Person berechtigt ist, den Datenabruf vorzunehmen.
 - c) Es MUSS durch technische Maßnahmen sichergestellt sein, dass die konkrete Abrufberechtigung ausschließlich für einen einzigen Abruf berechtigt, für einen weiteren Abruf also eine neue Bestätigung der Abrufberechtigung erfolgt. Alternativ DARF auch zu mehreren Abrufen desselben Autors innerhalb eines kurzen Zeitraumes berechtigt werden.
 - d) Im Rahmen der konkreten Abrufberechtigung MÜSSEN die festgestellten Identitätsparameter des konkreten Abrufenden unter Einhaltung der rechtlichen Vorgaben protokolliert werden.
 - e) Die Authentisierung des konkreten Nutzers gegenüber dem IDA MUSS mindestens auf dem Vertrauensniveau „substantiell“ erfolgen.
- [XBd.2.2] Bei automatisierten Abrufen zur Erfüllung der Aufgaben einer registerführenden Stelle gemäß § 2 Nr. 1f. IDNrG sowie für einen registerbasierten Zensus ist die Umsetzung der Anforderung [XBd.2.1] in der Regel nicht möglich. Wird für derartige Abrufe dennoch eine konkrete Abrufberechtigung durchgeführt, MUSS durch technische Maßnahmen sichergestellt werden, dass ein Abruf des Autors von dem Abruf durch andere Autoren unterschieden werden kann (z.B. durch die Ausstellung spezieller Authentisierungsmittel).

6.2.2 Protokollierung

- [XBd.3.1] Jeder Aufruf des IDA-Verfahrens MUSS protokolliert werden. Das Protokoll SOLLTE wie folgt zwischen den Rollen aufgeteilt werden:
- a) Das Sendesystem der Nachricht protokolliert
 - i. den Zeitpunkt, zu dem es die Nachricht Ende-zu-Ende-verschlüsselt oder den Ende-zu-Ende-Integritätsschutz angebracht hat, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt¹,

¹ Ein nicht expliziter Bearbeitungsschritt liegt dann vor, wenn die Nachricht als Teil eines kontinuierlichen Nachrichtenstroms fortlaufend verschlüsselt und übertragen wird, da hier die Verschlüsselung fortlaufend während der Kommunikation (und nicht etwa explizit vor der Kommunikation) erfolgt und daher ein konkreter Verschlüsselungszeitpunkt nicht zugeordnet werden kann.

- ii. den Zeitpunkt, zu dem er die Nachricht an die nächste Stelle im Transportweg weitergeleitet hat, also beispielsweise an den Leser oder an ein Intermediärsystem auf dem Transportweg,
 - iii. den Zeitpunkt, zu dem eine Transportverschlüsselung oder –integritätssicherung an der Nachricht angebracht wurde, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt, sowie
 - iv. die Identität des nächsten Systems im Übertragungsweg.
- b) Intermediärsysteme auf dem Transportkanal (sofern vorhanden) protokollieren
- i. den Zeitpunkt, zu dem Nachrichten eingegangen oder weitergeleitet werden,
 - ii. den Zeitpunkt, zu dem eine Transportverschlüsselung oder –integritätssicherung an einer Nachricht angebracht, überprüft, oder entfernt wurde, sofern dies explizite Bearbeitungsschritte in der Kommunikation darstellt,
 - iii. im Falle einer Überprüfung der Integritätssicherung, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt, das Ergebnis sowie das hierfür angewandte Verfahren sowie
 - iv. die beteiligten Akteure, also das System, welches die Nachricht an das Intermediärsystem übermittelt hat, sowie das System, an welches das Intermediärsystem weiterleiten wird, sowie Autor und Leser einer Nachricht.
- c) Der Leser der Nachricht protokolliert
- i. den Zeitpunkt, zu dem eine Nachricht eingeht,
 - ii. den Zeitpunkt, zu dem eine Transportverschlüsselung oder –integritätssicherung an einer Nachricht überprüft oder entfernt wurde, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt,
 - iii. den Zeitpunkt, zu dem die Ende-zu-Ende-Verschlüsselung einer Nachricht entfernt wurde, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt,
 - iv. im Falle einer Überprüfung der Integritätssicherung, sofern dies einen expliziten Bearbeitungsschritt in der Kommunikation darstellt, das Ergebnis sowie das hierfür angewandte Verfahren,
 - v. die beteiligten Akteure, also den Autor sowie ggf. das Intermediärsystem, von dem die Nachricht empfangen wurde,
 - vi. das Ergebnis der Schemavalidierung und
 - vii. ob bei der Bearbeitung einer Nachricht Fehler aufgetreten sind. Falls ja, auch der Fehlertyp.
- [XBd.3.2] Für Antworten MUSS dementsprechend vorgegangen werden, wobei auf den Tausch der Rollen in der Kommunikation zu achten ist. Ferner MÜSSEN Autor und Leser protokollieren, auf welche Anfrage sich eine Antwort bezieht.

7 Sichere Anschlussknoten

Zur Kommunikation im NOOTS werden von der Registermodernisierungsbehörde Sichere Anschlussknoten (SAKs) entwickelt und an alle anzubindenden Stellen verteilt. Zur Anbindung der DC und DP an das NOOTS sind diese SAKs verpflichtend einzusetzen. Die Verantwortung für den Betrieb der SAKs liegt bei den betriebsverantwortlichen Stellen der DC und DP und nicht bei der Registermodernisierungsbehörde (RMB). IT-Sicherheitsanforderungen an die fachverantwortlichen und betriebsverantwortlichen Stellen der DC und DP in Bezug auf den Einsatz der SAKs werden separat in der TR-03190 ("IT-Sicherheitsanforderungen für die Anbindung an das NOOTS") adressiert. Das vorliegende Kapitel befasst sich mit den IT-sicherheitstechnischen Anforderungen, die von der RMB bei der Entwicklung und Bereitstellung der SAKs beachtet werden müssen sowie mit den Anforderungen, die an die SAKs zu stellen sind.

Der SAK des DC nimmt im Rahmen der NOOTS-Sicherheitsarchitektur eine eher untergeordnete Rolle ein. Er dient vorrangig dem DC als Hilfsmittel, das alle Schritte des Nachweisabrufprozesses inklusive Anforderung des Zugriffstokens über die Teilnahmeberechtigung am NOOTS beim IAMfB, Ermittlung des zuständigen DP sowie seiner Verbindungsparameter mittels der RDN sowie abstrakter Berechtigungsprüfung mit Hilfe der Vermittlungsstelle initiiert. Des Weiteren übernimmt er im Zusammenspiel mit dem SAK des DP zentrale Aufgaben bei der Ver- und Entschlüsselung von Nachrichten. Nach Empfang des angeforderten Nachweises führt er eine Schemavalidierung durch, um sicherzustellen, dass keine vom erwarteten XNachweis-Nachrichtentyp abweichenden Dateien zum DC weitergeleitet werden. Darüber hinaus ist geplant, dass er eine Möglichkeit für die SAK-betreibende Stelle bietet, einen zusätzlichen Virens Scanner einzubauen, um den DC über eine reine Schemavalidierung hinaus vor Malware zu schützen.

Dem SAK des DP kommt im Rahmen der Sicherheitsarchitektur von NOOTS eine zentrale Rolle zu. Er wirkt als PEP (Policy Enforcement Point) der zugrundeliegenden Zero Trust Architektur: Während beispielsweise das IAM für Behörden als Policy Decision Point über die Teilnahmeberechtigung einer nachweisanfragenden Komponente entscheidet, setzt der SAK des DP diese Entscheidung durch, indem er die Nachweisanfrage nur bei Vorliegen eines vom IAM für Behörden gesiegelten und gültigen Zugriffstokens an den DP weiterleitet. Dennoch entbindet das den DP nicht von seiner Pflicht, sich selbst von der Rechtmäßigkeit der Anfrage zu überzeugen, weswegen der SAK des DP alle zu prüfenden Token zusätzlich an den DP weiterleitet.

Zusätzlich zu den Anforderungen, die die SAKs NOOTS-seitig erfüllen müssen, um einen reibungslosen, regelkonformen und sicheren Nachweisabruf zu ermöglichen, werden hier Anforderungen aufgelistet, die im Zusammenspiel zwischen SAK und DC bzw. DP vom SAK zu erfüllen sind. Die entsprechenden Anforderungen, die in diesem Zusammenhang von den DCs und DPs selbst zu erfüllen sind, finden sich in der TR-03190, „Anschlussbedingungen an das NOOTS“.

7.1 Build-, Release- und Deploymentmanagement

- [SAK.1.1] Es MUSS ein Build-, Release- und Deploymentmanagement umgesetzt werden, welches Prozesse zur Erstellung, Prüfung und Verteilung der Builds und Releases sowie zum Deployment enthält.
- [SAK.1.2] Die erstellte Software SOLLTE vor Auslieferung einer neuen Version einem externen Codeaudit unterzogen werden.
- [SAK.1.3] Der Hersteller bzw. Entwickler der SAKs MUSS eine zentrale und vollständige Liste von Abhängigkeiten durch externe Software, Bibliotheken und Frameworks führen. Es SOLLTE eine Software Bill of Materials (SBOM), wie in der BSI TR-03183-2 „Cyber-Resilienz-Anforderungen an Hersteller und Produkte“ (12) gefordert, erstellt und geführt werden.
- [SAK.1.4] Falls Drittsoftware verwendet wird, MUSS Software aus vertrauenswürdigen Quellen verwendet werden. Nicht verwendete Funktionen SOLLTEN deaktiviert werden.

- [SAK.1.5] Eingesetzte (Dritt-) Software MUSS in einer Version verwendet werden, die mit Sicherheitsupdates versorgt wird. Wenn für die Anwendung relevante Schwachstellen in verwendeter Software bekannt werden, MÜSSEN die zugehörigen Sicherheitsupdates kurzfristig eingespielt werden. Die Umsetzungszeit MUSS der Kritikalität und Ausnutzbarkeit der Schwachstelle entsprechend angemessen gewählt werden. Software, die nicht länger vom Hersteller oder Entwickler gewartet wird, DARF NICHT verwendet werden.
- [SAK.1.6] Alle erstellten Softwarepakete und Updates MÜSSEN vor der Auslieferung mindestens fortgeschritten signiert werden.
- [SAK.1.7] Versionierungen SOLLTEN verständlich und nachvollziehbar gewählt werden. Release Notes MÜSSEN erstellt werden. Insbesondere SOLLTEN Informationen zu sicherheitskritischen Updates und Supportdauer einer Version enthalten sein.
- [SAK.1.8] Es MUSS durch technische Maßnahmen sichergestellt sein, dass alle NOOTS-Teilnehmer eine aktuelle Softwareversion der SAKs verwenden. Es DARF NICHT möglich sein, mit veralteten Versionen über die Übergangszeit hinaus am IAM für Behörden ein Token über die Teilnahmeberechtigung als NOOTS-Teilnehmer zu erlangen. Die Übergangszeit MUSS entsprechend der Kritikalität des Updates gewählt sein und MUSS an alle NOOTS-Teilnehmer kommuniziert werden.
- [SAK.1.9] Der SAK SOLLTE als Application-Level-Gateway (ALG) konzipiert sein, damit er in der demilitarisierten Zone (DMZ) der betriebsverantwortlichen Stelle des dazugehörigen DC bzw. DP als Teil der PAP-Struktur zwischen zwei Firewalls eingesetzt werden kann. Es MUSS für die betriebsverantwortliche Stelle auch möglich sein, den SAK im Sinne einer erhöhten Absicherung hinter einer PAP-Struktur oder als Erweiterung der PAP-Struktur zu betreiben.
- [SAK.1.10] Die Verbindungsdaten und Zertifikate der zentralen NOOTS-Komponenten (IAM, RDN, IDM für Personen, VS) MÜSSEN in den SAKs der NOOTS-Teilnehmer bei Auslieferung hinterlegt sein.

7.2 Kryptographische Anforderungen

- [SAK.2.1] Es DÜRFEN NUR Protokolle eingesetzt werden, die kryptografische Algorithmen verwenden, welche gemäß der TR-03116-4 (19) zulässig sind und gemäß TR-02102-1 (16) bzw. TR-02102-2 (15) dem Stand der Technik entsprechen. Kryptographische Verfahren werden für folgende Zwecke eingesetzt:
1. Die Sicherstellung der Vertraulichkeit auf Inhaltsdatenebene (Ende-zu-Ende-Verschlüsselung),
 2. die Sicherstellung der Vertraulichkeit auf Transportebene (Transportverschlüsselung),
 3. die Sicherstellung der Integrität und Authentizität auf Inhaltsdatenebene (Ende-zu-Ende-Verifikation) sowie
 4. die Sicherstellung der Integrität und Authentizität auf Transportebene (Transportverifikation).
- [SAK.2.2] Es MUSS eine Ende-zu-Ende-Inhaltsverschlüsselung für die Verschlüsselung der Fachdaten zwischen dem SAK des DC und dem SAK des DP sowie bei der Antwort zwischen dem SAK des DP und dem SAK des DC eingesetzt werden. Kommen bei der Übermittlung der Fachdaten mehr als zwei technische Systeme zum Einsatz, so MÜSSEN alle Intermediärsysteme ihren Dienst ohne Kenntnis der Fachdaten erfüllen können und DÜRFEN NICHT in die Lage versetzt werden, Fachdaten im Klartext einzusehen.
- [SAK.2.3] Es MUSS eine Transportverschlüsselung für die Verschlüsselung der Transportnachricht jeweils zwischen zwei Systemen eingesetzt werden. Diese Transportverschlüsselung DARF an Intermediärsystemen aufgebrochen werden und MUSS für den weiteren Transport der Nachricht wieder hergestellt werden.
- [SAK.2.4] Es MUSS ein Konzept entwickelt werden, welches für den Fall der Weiterentwicklung der Verschlüsselungs- bzw. Datenauthentisierungsverfahren oder des Diebstahls von Schlüsseln oder Ähnlichem den Austausch der Verfahren und/oder des kryptografischen Materials ermöglicht und zwingend vorschreibt (Krypto-Agilität).

- [SAK.2.5] Die zur Kommunikation verwendeten Verschlüsselungsverfahren insbesondere für die Inhaltsdatenverschlüsselung SOLLTEN postquantensicher sein.
Im Falle von Schlüsselaustauschverfahren bedeutet das, dass eine Kombination aus klassischen und quantensicheren Verfahren verwendet werden SOLLTE. Im Falle von symmetrischer Verschlüsselung MUSS eine ausreichende Schlüssellänge verwendet werden.
- [SAK.2.6] Zwischen Sende- und Empfangssystem einer Nachricht MUSS ein Datenauthentisierungsverfahren verwendet werden. Wird ein symmetrisches Datenauthentisierungsverfahren verwendet, MUSS es mit einem ephemeren Schlüsseleinigungsverfahren kombiniert werden.
- [SAK.2.7] Das Datenauthentisierungsverfahren MUSS sicherstellen, dass sich das Empfangssystem vergewissern kann, dass die Nachricht auf dem Transportweg nicht verändert wurde, sondern in der übermittelten Form vom Sendesystem abgesendet wurde (Integrität).
- [SAK.2.8] Werden Intermediäre zur Kommunikation verwendet, so MUSS zwischen zwei Intermediären sowie zwischen einem Intermediär und einem Sende- oder Empfangssystem ein Datenauthentisierungsverfahren verwendet werden, das die Integrität der Transportnachricht auf dem Transportkanal sicherstellt.
- [SAK.2.9] Enthält eine Fach- oder Transportnachricht ein technisches Verfahren zur Datenauthentisierung, so MUSS vor der Auswertung von Fachdaten zunächst eine Überprüfung der Gültigkeit des Schlüsselmaterials und anschließend der Integrität der Nachricht erfolgen. Konnte die Prüfung nicht erfolgreich abgeschlossen werden, so MUSS die Nachricht abgewiesen werden. Eine Fehlermeldung SOLLTE an das sendende System gesandt werden.
- [SAK.2.10] Für die Verwaltung des kryptografischen Materials MUSS mindestens das Security Level 1 gemäß der Key Lifecycle Security Requirements (14) eingehalten werden.

7.3 Nachrichtenvalidierung

In der öffentlichen Verwaltung werden verschiedene Standards zur Darstellung von Daten in maschinenlesbaren Dateiformaten verwendet. Die Einhaltung dieser standardisierten Dateiformate ist sehr wichtig, um eine fehlerfreie Datenverarbeitung durch andere Systeme sicherzustellen. Daher sind folgende Anforderungen an die Nachrichtenvalidierung zu erfüllen:

- [SAK.3.1] Alle eingesetzten Standards zur Übermittlung MÜSSEN eine Beschreibung des Nachrichtenaufbaus enthalten (z.B. ein Schema in einer konkreten Ausprägung, ggf. mit Versionsnummer), die den Aufbau einer korrekten Nachricht sowie die hierfür zulässigen Datentypen beschreibt.
- [SAK.3.2] Jedes Empfangssystem MUSS vor der semantischen Auswertung einer Fachnachricht anhand der Beschreibung des Nachrichtenaufbaus eine Validierung der Korrektheit des Nachrichtenaufbaus durchführen.
- [SAK.3.3] Vor der Entschlüsselung der gemäß [SAK.2.2] gesicherten Fachnachricht MUSS die für deren Transport verwendete Transportnachricht anhand der Beschreibung ihres Nachrichtenaufbaues validiert werden.
- [SAK.3.4] Falls Fachdaten mit Hilfe eines Transportprotokolls übertragen werden, das die Fachdaten mit zusätzlichen Metadaten anreichert, so SOLLTEN alle an dem Transport beteiligten Systeme vor dem Verarbeiten der Metadaten der Transportnachricht oder dem Entpacken der Fachdaten die Transportnachricht anhand der Beschreibung des Nachrichtenaufbaus des verwendeten Transportprotokolls validieren.
- [SAK.3.5] Bei fehlgeschlagener Validierung MÜSSEN die Nachrichten abgelehnt werden, ein manueller Reparaturprozess ist nicht zulässig.
- [SAK.3.6] Fehlerhafte Nachrichten DÜRFEN NICHT außerhalb der Fehleranalyse gespeichert werden. Sie DÜRFEN NICHT ohne zusätzliche Sicherungsmaßnahmen geloggt werden.

- [SAK.3.7] Aus Fehlermeldungen zu Validierungen DARF NICHT der Grund der Ablehnung ersichtlich sein.

7.4 Fehlerbehandlung

- [SAK.4.1] Stellt eine der beteiligten Parteien fest, dass eine der MUSS-Anforderungen dieser Technischen Richtlinie im Rahmen der Übermittlung einer Nachricht verletzt wurde, so MUSS die Nachricht abgewiesen werden und DARF NICHT weiterverarbeitet werden. Dem Sendesystem der Nachricht SOLLTE eine Fehlermeldung zugeschickt werden.
- [SAK.4.2] Die genaue Ausgestaltung der Fehlermeldungen ergibt sich aus dem für die Fachdaten verwendeten Standard. Falls im Rahmen der Übermittlung der Nachricht der Verstoß gegen eine der MUSS-Anforderungen dieser TR bereits in der Auswertung, Verarbeitung oder Konstruktion der Transportnachricht festgestellt wurde, so SOLLTE alternativ eine Fehlermeldung zugesendet werden, deren Ausgestaltung von dem Standard auf Transportebene vorgegeben wird.
- [SAK.4.3] Die Fehlermeldungen DÜRFEN NICHT Rückschlüsse auf oder Einblicke in die Funktionsweise des Kommunikationspartners bieten. Es SOLLTEN vordefinierte Fehlermeldungen und formal prüfbare Fehlercodes für die Rückmeldung an anfragende Systeme verwendet werden.
- [SAK.4.4] Die Fehlermeldungen DÜRFEN NICHT personenbezogene Daten enthalten.
- [SAK.4.5] Nachrichten, die einem an der Datenübermittlung beteiligten System vorliegen, DÜRFEN NICHT länger als notwendig aufbewahrt werden. Schlägt die Weiterleitung fehl, MÜSSEN sie gelöscht werden.
- [SAK.4.6] Im Falle der Nichtzustellung einer Nachricht MUSS dem Sendesystem der Nachricht eine Fehlermeldung zugeschickt werden. Konnte eine Fehlermeldung nicht zugestellt werden, entfällt dies, allerdings SOLLTE dann eine manuelle Klärung des Kommunikationsproblems erfolgen.
- [SAK.4.7] Erhält ein System eine Fehlermeldung, so DARF es darauf NICHT mit einer eigenen Fehlermeldung an das System, das ihm die Fehlermeldung gesendet hat, antworten. Die Fehlermeldung MUSS stattdessen protokolliert werden. Gegebenenfalls SOLLTE eine manuelle Klärung erfolgen.

7.5 Sicherer Anschlussknoten für Data Consumer

- [SAK.5.1] Der SAK des DC MUSS die Server-TLS-Zertifikate der zentralen NOOTS-Komponenten und der SAKs der DPs zu Beginn jeder Kommunikaton auf Gültigkeit prüfen.
- [SAK.5.2] Der SAK des DC MUSS in der Lage sein, die Teilnahmeart seiner Kommunikationspartner am Datenaustausch über das NOOTS zu ermitteln. Er MUSS den Verbindungsaufbau abbrechen, wenn diese nicht der erwarteten Teilnahmeart entspricht.
- [SAK.5.3] Falls der SAK des DC kein zeitlich gültiges Zugriffstoken gemäß [Z.2.3] für den anfragenden DC hält, MUSS der SAK des DC sich zu Beginn eines Nachweisabrufs gegenüber der zentralen NOOTS-Komponente IAM für Behörden authentifizieren und zusätzlich die Authentifizierungsinformationen des DC, für den er tätig ist, weitergeben.
- [SAK.5.4] Der SAK des DC MUSS für jede Nachweisabfrage den zuständigen DP und dessen Verbindungsparameter bei der RDN ermitteln. Er MUSS das Siegel der RDN auf den so erhaltenen Verbindungsparametern verifizieren.
- [SAK.5.5] Der SAK des DC MUSS für jede Nachweisabfrage eine abstrakte Berechtigungsprüfung durch die VS anstoßen.
- [SAK.5.6] Der SAK des DC MUSS vor der Verschlüsselung und Weiterleitung einer Nachricht durch Schemavalidierung prüfen, dass diese dem vorgegebenen XNachweis-Aufbau entspricht.
- [SAK.5.7] Der SAK des DC MUSS für jede Nachweisabfrage die Inhaltsdaten der Nachweisabfrage für den SAK des DP verschlüsseln. Diese Inhaltsdatenverschlüsselung MUSS als Ende-zu-Ende-Verschlüsselung wirken, die nur für den SAK des DP entschlüsselbar ist.
- [SAK.5.8] Der SAK des DC MUSS das Zugriffstoken des IAM für Behörden, das Zuständigkeitstoken der Registerdatennavigation und das Abruftoken der Vermittlungsstelle zusammen mit den verschlüsselten Inhalten der Nachweisanfrage und ggf. dem Token vom IDM für Personen, das die

IDNr. enthält, und ggf. einem Token, das die Authentifizierung der anfragenden Person bestätigt, für den Transport verschlüsseln. Hierfür MUSS die TR-02102-2 beachtet werden. Die so verschlüsselte Anfrage MUSS anhand der Verbindungsparameter, die der SAK des DC von der RDN erhalten hat, an den SAK des betreffenden DP gesendet werden.

- [SAK.5.9] Bei eingehenden angefragten Nachweisen MUSS der SAK des DC anhand der Transportverschlüsselung überprüfen, dass die eingehende Nachricht von dem SAK des zuvor angefragten DP stammt. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.5.10] Nach Entfernen der Transportverschlüsselung MUSS der SAK des DC das Siegel des DP verifizieren. Wenn alle Prüfungen bis zu diesem Punkt keine Auffälligkeiten ergeben haben, MUSS der SAK des DP die Inhalte der Nachricht entschlüsseln. Andernfalls DARF er sie NICHT entschlüsseln.
- [SAK.5.11] Der SAK des DC MUSS nach dem Entschlüsseln der Inhalte eine Schemavalidierung anhand des zu erwartenden Nachrichtenaufbaus durchführen. Schlägt diese fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.5.12] Alle oben beschriebenen Fehlerfälle MÜSSEN geloggt und die Logging-Daten der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden. Eine Fehlermeldung SOLLTE an den Kommunikationspartner versandt werden. Sie DARF KEINE Rückschlüsse auf das verwendete Verifikationsschema zulassen, um ein Herantasten unberechtigter Nutzer an eine korrekte Nachricht zu erschweren.
- [SAK.5.13] Alle erfolgreich durchgeführten Nachweisabrufe MÜSSEN geloggt werden und die Logging-Daten der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden.
- [SAK.5.14] Der SAK des DC SOLLTE eine Möglichkeit bieten, einen Virens Scanner einzubinden.
- [SAK.5.15] Der SAK des DC MUSS die empfangenen Daten für die Weiterleitung an den DC erneut verschlüsseln. Diese Verschlüsselung muss mindestens den Anforderungen der TR-02102-2 genügen.

7.6 Sicherer Anschlussknoten für Data Provider

- [SAK.6.1] Der SAK des DP MUSS den oder die DP(s), für den oder die er betrieben wird, vor jeder Interaktion mit ihnen sicher identifizieren und authentifizieren.
- [SAK.6.2] Der SAK des DP MUSS zu Beginn jeder Interaktion die SAKs der DCs anhand der Client-TLS-Zertifikate als zugehörig zum jeweiligen DC identifizieren.
- [SAK.6.3] Bei jedem Nachweisabruf MUSS der SAK des DP verifizieren, dass dieser von einem NOOTS-Teilnehmer stammt. Er MUSS die Teilnahmeberechtigung dieses NOOTS-Teilnehmers über das mitgelieferte, vom IAM für Behörden gesiegelte Zugriffstoken nachprüfen. Hierbei MÜSSEN Siegelung und Zeitstempel geprüft werden. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.4] Der SAK des DP MUSS überprüfen, dass die mitgelieferten, von der RDN gesiegelten Daten über Name und ID des angefragten DP seinen eigenen entsprechen. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.5] Bei Nachweisabrufen unter Verwendung der IDNr. MUSS der SAK des DP das entsprechende, beigefügte Token des IDA-Abrufs nachprüfen bezüglich Siegelung und Zeitstempel. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.6] Der SAK des DP MUSS das Siegel des SAK des DC auf dem übersendeten Krypto-Container verifizieren. Wenn alle Prüfungen bis zu diesem Punkt keine Auffälligkeiten ergeben haben, MUSS der SAK des DP die Inhalte der Nachricht entschlüsseln. Andernfalls DARF er sie NICHT entschlüsseln.
- [SAK.6.7] Der SAK des DP MUSS eine Schemavalidierung der entschlüsselten Nachricht durchführen.
- [SAK.6.8] Der SAK des DP MUSS überprüfen, dass der Inhalt der Nachweisabfrage dem mitgelieferten Abruftoken der VS entspricht, dass das Abruftoken von der VS gesiegelt wurde und zeitlich gültig ist sowie, dass der im Abruftoken hinterlegte Hashwert zu der Nachweisabfrage passt.

- [SAK.6.9] Bei jedem Nachweisabruf, der durch eine natürliche Person angestoßen wurde, MUSS der SAK des DP nachprüfen, dass die Identität der Person durch Authentifizierung auf dem erforderlichen Vertrauensniveau (normal, substantiell oder hoch – je nach Anforderungen des angestrebten Nachweises) sichergestellt ist. Hierfür MUSS der SAK des DP nachprüfen, dass das mit gesendete Authentifizierungstoken eine gültige Siegelung von der dafür im NOOTS oder außerhalb des NOOTS zuständigen Stelle aufweist und zeitlich gültig ist. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.10] Ist mindestens eine der genannten Überprüfungen fehlgeschlagen, DARF der SAK des DP die Nachricht nicht weiterverarbeiten. Er MUSS den Vorgang loggen und die Logging-Daten der Monitoring-Zentralstelle zur Auswertung zur Verfügung stellen. Er SOLLTE eine Fehlermeldung an den Kommunikationspartner senden, die es aber nicht erlauben darf, Rückschlüsse auf die zugrunde liegenden Sicherheitsmechanismen zu ziehen.
- [SAK.6.11] Sind alle Überprüfungen erfolgreich durchgeführt worden, MUSS der SAK des DP allegeprüften Token gemeinsam mit der Nachweisabfrage an den angeschlossenen DP weiterleiten, damit dieser die Überprüfungen im Sinne von Zero Trust wiederholen kann. Der Vorgang MUSS geloggt werden und die Logging-Daten der Monitoring-Zentralstelle zur Auswertung zur Verfügung gestellt werden. Geloggt werden MÜSSEN mindestens der Zeitpunkt, die an der Übermittlung beteiligten Systeme, eine Nachrichtenidentifikationsnummer und das Ergebnis der Konformitätsprüfungen im SAK. Diese Logging-Daten DÜRFEN KEINE Inhaltsdaten enthalten.
- [SAK.6.12] Der SAK des DP MUSS die Transportnachricht, welche Nachweisanfrage und Token enthält, erneut verschlüsseln, bevor er sie an den DP weitersendet. Die Verschlüsselung MUSS mindestens die Anforderungen der TR-02102-2 erfüllen.
- [SAK.6.13] Für den Versand des angefragten Nachweises an den SAK des DC, der die Anfrage gesendet hat, MUSS der SAK des DP die Inhaltsdaten für den SAK des DC verschlüsseln. Hierbei MÜSSEN die Anforderungen der TR-02102-1 erfüllt werden. Die Inhalte MÜSSEN Ende-zu-Ende verschlüsselt bis zum SAK des DC gesendet werden.
- [SAK.6.14] Zusätzlich MUSS der SAK des DP die Rückantwort transportverschlüsseln. Hierbei MÜSSEN die Anforderungen der TR-02102-2 erfüllt werden.
- [SAK.6.15] Die Antwortnachricht DARF NUR an den SAK des DC weitergeleitet werden, der die Anfrage, die damit beantwortet wird, gestellt hat. Hierfür kann beispielsweise die Nachrichtenidentifikationsnummer verwendet werden.

Literaturverzeichnis

1. Deutscher Bundestag: Datenaustausch zwischen öffentlichen Stellen von Bund und Ländern - NOOTS Staatsvertrag. [Online] 13. Oktober 2025. <https://www.bundestag.de/dokumente/textarchiv/2025/kw26-de-noots-1084816>.
2. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03172 Portalverbund. [Online] 14. November 2024. <https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03172/tr-03172.html>.
3. Bundesamt für Sicherheit in der Informationstechnik (Hrsg.). *IT-Grundschutz-Kompendium*. Edition 2023. Köln : Reguvis, 2023. ISBN 978-3-8462-0906-6.
4. S. O. Bradner. RFC 2119 - Key words for use in RFCs to Indicate Requirement Levels. [Online] März 1997. <https://www.rfc-editor.org/info/rfc2119>.
5. Bundesamt für Sicherheit in der Informationstechnik. BSI-Standard 200-1: Managementsysteme für Informationssicherheit (ISMS). [Online] 15. November 2017. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_1.html?nn=128578.
6. —. BSI-Standard 200-2: IT-Grundschutz-Methodik. [Online] 15. November 2017. <https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-2-IT-Grundschutz-Methodik/bsi-standard-200-2-it-grundschutz-methodik.html>.
7. —. BSI-Standard 200-3: Risikomanagement. [Online] 15. 11 2017. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-3-Risikomanagement/bsi-standard-200-3-risikomanagement_node.html.
8. International Organization for Standardization (Hrsg.). *ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements*. 2022.
9. Bundesamt für Sicherheit in der Informationstechnik. BSI-Standard 200-4: Business Continuity Management. [Online] 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/bsi-standard-200-4_Business_Continuity_Management_node.html.
10. International Organization for Standardization (Hrsg.). *ISO 22301:2019, Security and resilience - Business continuity management systems - Requirements*. 2019.
11. Foudil, Edwin und Shafranovich, Yakov. RFC 9116 - A File Format to Aid in Security Vulnerability Disclosure. [Online] April 2022. <https://www.rfc-editor.org/info/rfc9116>.
12. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03183 - Cyber-Resilienz-Anforderungen: Teil 2 "Software Bill of Materials (SBOM)". [Online] 20. August 2025. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03183/TR-03183_node.html.
13. —. Mindeststandard des BSI zur Protokollierung und Detektion von Cyberangriffen. [Online] November 2024. https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Mindeststandards/PDCA/PDCA_node.html.
14. —. Key Lifecycle Security Requirements - Version 1.0.3. [Online] 17. November 2021. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/ElekAusweise/CVCA/KeyLifecycleSecurityRequirements.pdf?__blob=publicationFile&v=3.

15. —. BSI TR-02102-2 - Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS). [Online] 21. Januar 2025. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr02102/tr02102_node.html.
16. —. BSI TR-02102-1 - Kryptographische Verfahren: Empfehlungen und Schlüssellängen. [Online] 31. Januar 2025. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr02102/tr02102_node.html.
17. Bundesverwaltungsamt. Spezifikation XBasisdaten 1.5. [Online] 31. Januar 2024. https://www.xrepository.de/details/urn:xoev-de:bva:standard:xbasisdaten_1.5.
18. Bundesamt für Sicherheit in der Informationstechnik. TR-03107 - Elektronische Identitäten und Vertrauensdienste im E-Government - Teil 1: Vertrauensniveaus und Mechanismen - Version 1.1.1. [Online] 7. Mai 2019. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03107/TR-03107_node.html.
19. —. BSI TR-03116 - Kryptographische Vorgaben für Projekte der Bundesregierung: Teil 4 - Kommunikationsverfahren in Anwendungen. [Online] 07. März 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03116/TR-03116_node.html.
20. Nachname, Vorname. *Titel eingetragen*. Bonn als Ort : Verleger eingetragen, 2019. ISBN 123456.

Abkürzungsverzeichnis

Abkürzung	Erklärung
ALG	Application Level Gateway
beWiNr	Bundeseinheitliche Wirtschaftsnummer für Unternehmen
BSI	Bundesamt für Sicherheit in der Informationstechnik
BVA	Bundesverwaltungsamt
BZSt	Bundeszentralamt für Steuern
DAMAS	Datenmanagementsystem
DC	Data Consumer
DP	Data Provider
EU-DSGVO	Europäische Datenschutz-Grundverordnung
EU-OOTS	Once-Only-Technical-System der Europäischen Union
HTTPS	HyperText Transfer Protocol - Secure
IAM	Identity and Access Management
IDM	Identity Management
IDA	Identitätsdatenabruf
IDNr.	Identifikationsnummer im Sinne des Identifikationsnummerngesetzes
IDNrG	Identifikationsnummerngesetz
IP	Internetprotokoll
NOOTS	Nationales Once-Only-Technical-System
OSCI	Online Service Computer Interface
OZG	Onlinezugangsgesetz
PAP-Struktur	Mehrstufige Sicherheitsarchitektur aus Paketfilter (P), ALG (A) & weiterem Paketfilter (P)
PKI	Public Key Infrastruktur
RDN	Registerdatennavigation
RMB	Registermodernisierungsbehörde
SAK	Sicherer Anschlussknoten
SDG	Single Digital Gateway
StBA	Statistisches Bundesamt
TDDs	Technical Design Documents – Technische Entwurfsdokumente
TLS	Transport Layer Security
TR	Technische Richtlinie
UBRegG	Unternehmensbasisdatenregistergesetz
VS	Vermittlungsstelle